



# Criptografia

## Segurança em Redes e Sistemas Informáticos

CTeSP em Redes e Sistemas Informáticos

Escola Superior de Tecnologia e Gestão de Águeda

Universidade de Aveiro

2025-26



# Terminologia

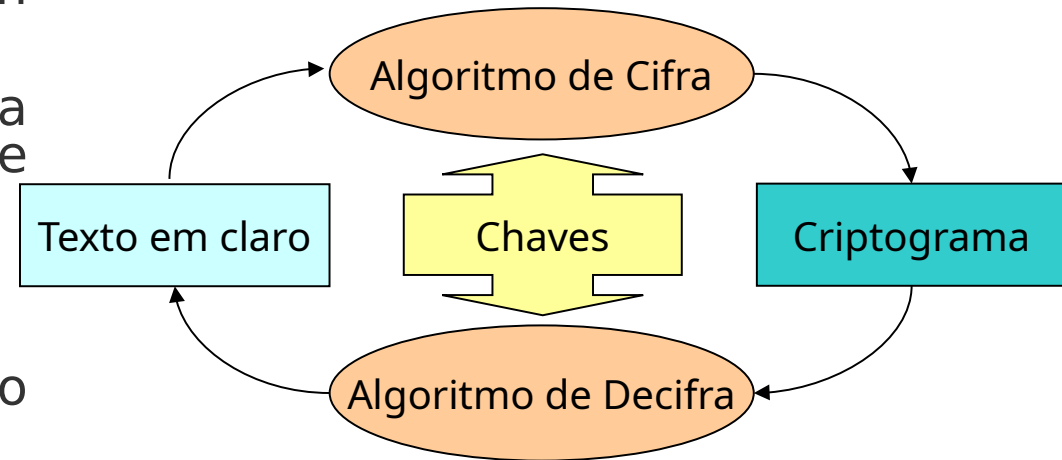
---

- Criptografia
  - Arte ou ciência de escrever uma mensagem de forma a ocultar o seu conteúdo
    - Escrita secreta
    - Protege o conteúdo de leituras não autorizadas
    - Não tem como objetivo esconder a existência da mensagem
- Permite que várias entidades comuniquem de forma ininteligível para terceiros
  - Esconde a informação de entidades terceiras não autorizadas
  - Garante a confidencialidade da informação
- Criptanálise
  - Arte ou ciência de violar sistemas criptográficos ou informação cifrada



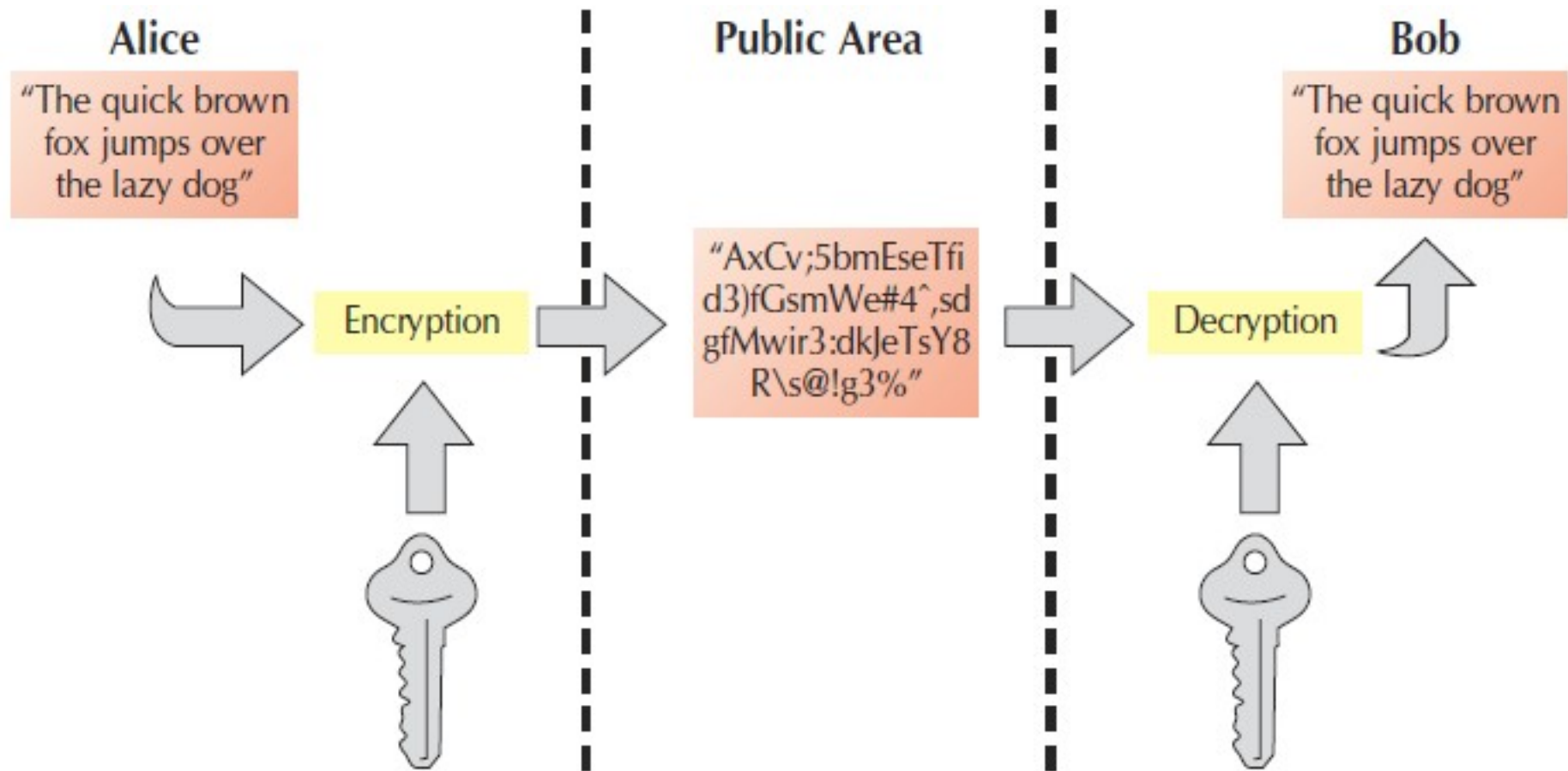
# Operação

- Algoritmo criptográfico (ou cifra, palavra de origem árabe)
  - Técnica criptográfica concreta para cifrar e decifrar um texto
- Chave
  - Parâmetro do algoritmo criptográfico
- Operação de uma cifra
  - Cifrar ou encriptar: Transformação de um texto em claro num texto cifrado ou criptograma
  - Decifrar ou descriptar: Transformação de um criptograma no texto em claro original





# Criptografia: Operação de uma cifra



Retirado de: <http://gdp.globus.org/gt4-tutorial/multiplehtml/ch09.html>



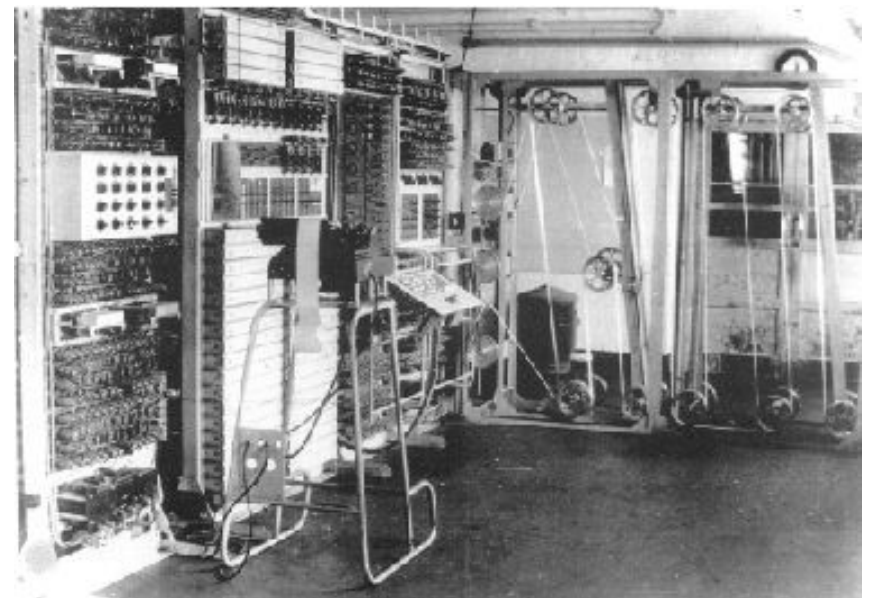
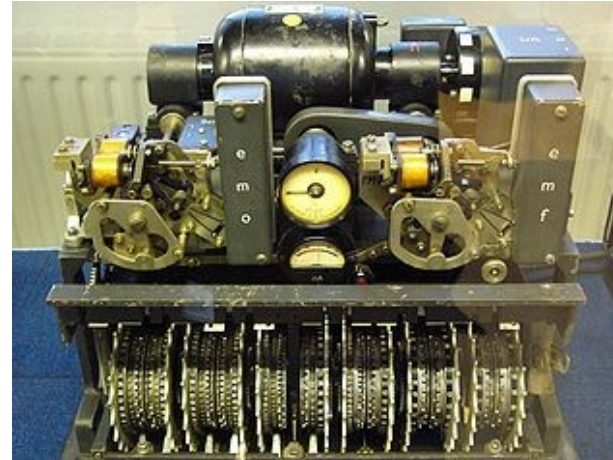
# Aproximações Base

---

- Aproximações base para a cifra (encriptar) informação são:
  - Transposição
    - Os símbolos do texto original são baralhados
    - Alteração da ordem dos símbolos no texto
  - Substituição
    - Cada símbolo original é substituído por outro símbolo
      - Originalmente os símbolos era letras, algarismos e pontuação
      - Atualmente os símbolos são blocos de bits
- Criptografia moderna usa funções matemáticas complexas
  - Resistentes à reversão ou à solução por outras formas que não sejam a utilização do algoritmo e da chave

# Cifras: Evolução da Tecnologia

- ▶ **Manuais**
  - ▶ Algoritmos de substituição ou transposição
- ▶ **Mecânicas**
  - ▶ A partir do século XIX
    - ▶ Máquina Enigma
    - ▶ Máquina Lorenz
  - ▶ Algoritmos de substituição ou transposição
- ▶ **Informáticas**
  - ▶ Surgem com o uso dos computadores
  - ▶ Algoritmos de substituição mais complexos
  - ▶ Algoritmos matemáticos







# Perspetiva histórica: Cifras por transposição

- Transposição
  - Os símbolos do texto original são baralhados
    - As suas posições no texto são alteradas
- Exemplo Clássico: Bastão de Licurgo ou Scytalae
  - Um bastão de madeira ao redor do qual se enrolava firmemente uma tira de couro ou pergaminho, longa e estreita.
  - A mensagem era escrita no sentido do comprimento do bastão e depois a tira era desenrolada, contendo a mensagem cifrada.
  - <http://www.numaboa.com.br/crptografia/transposicoes/322-bastao-de-licurgo>





# Perspetiva histórica: Cifras por transposição

---

- Escrita em colunas
  - O TEXTO ORIGINAL É BARALHADO

|   |   |   |   |   |   |   |   |
|---|---|---|---|---|---|---|---|
| O | X | O | G | A | B | A | A |
| T | T | R | I | L | A | L | D |
| E | O | I | N | E | R | H | O |

- Permutações intra-blocos (permutacoesintrablocos)
  - (13524)  $\Rightarrow$  pmeur toaec stirn aobcl os pruem tceao snrit alcbo os
  - (25413)  $\Rightarrow$  mpure oteca tsrni oaclb os





# Lab

---

- Aceda à página da aplicação JCrypTool
  - <https://www.cryptool.org/>
- Use a aplicação online, seleccionando CrypTool online
  - Pode também descarregar e instalar uma versão da aplicação.
- Dentro das cifras clássicas, explore a cifra “Simple Column Transposition”
  - O algoritmo de transposição é um dos usados anteriormente?



# Perspetiva histórica: Cifras por Substituição

## Tipos de Substituição

---

- Cifras Mono-alfabéticas (um $\Rightarrow$ um)
  - Usam apenas um alfabeto de substituição
  - A um símbolo do alfabeto do texto em claro corresponde um símbolo do alfabeto de substituição
- Cifras Poli-alfabéticas (vários um $\Rightarrow$ um)
  - Usam N alfabetos de substituição
  - A um símbolo do alfabeto do texto em claro corresponde um símbolo de um dos vários alfabetos de substituição

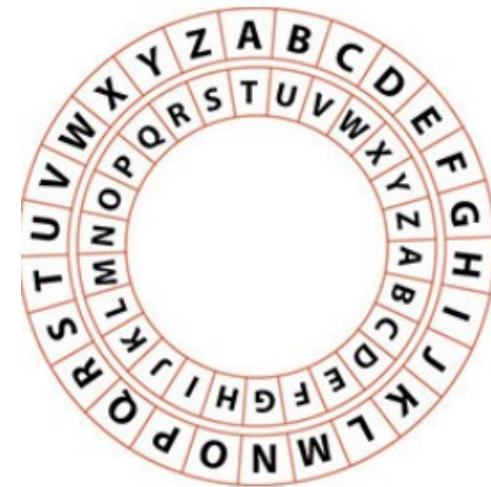
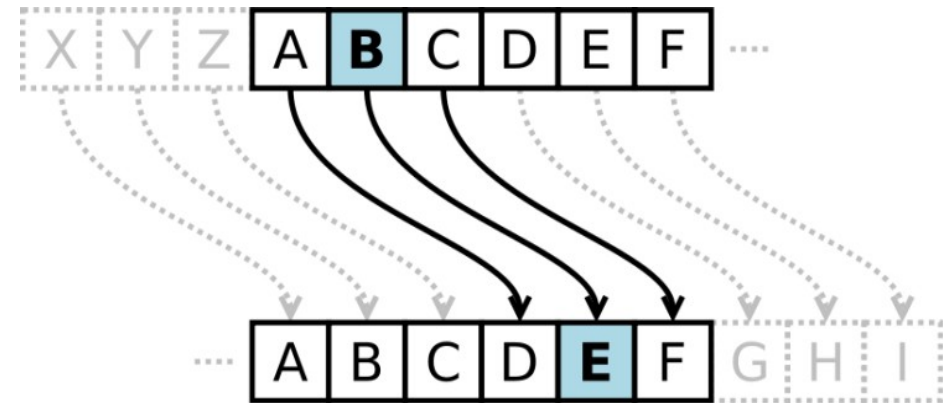


# Perspetiva histórica: Cifras mono-alfabéticas

- Usam apenas um alfabeto de substituição, com um número de símbolos #A

- Exemplos

- Aditivas (ou de translação), ROTXX
  - Espaço de Chaves: Número de chaves efectivas = #A
  - Cifra:  $\text{cripto\_letra} = (\text{letra} + \text{chave}) \bmod \#A$
  - Decifra:  $\text{letra} = (\text{cripto\_letra} - \text{chave}) \bmod \#A$
  - Ex: Cifra de César (ROT3): chave = 3
- Com frase-chave
  - ABCDEFGH IJKLMNOPQRSTUVWXYZ
  - Q TUWXYZ COMFRASEHV BDGIJ KLNP
  - A frase chave posiciona-se debaixo da letra chave (H, no exemplo)
  - Espaço de Chaves = #símbolos alfabeto !  $\Rightarrow 26! \approx 2^{88}$



- Problemas

- Reproduzem padrões do texto original: Letras, bigramas, trigramas, etc.
- A análise estatística facilita a criptanálise
  - [https://pt.wikipedia.org/wiki/Frequência\\_de\\_letras](https://pt.wikipedia.org/wiki/Frequência_de_letras)
  - [http://en.wikipedia.org/wiki/Letter\\_frequency](http://en.wikipedia.org/wiki/Letter_frequency)



# Lab 2

---

- Usando o JcryptTool, dentro das cifras clássicas, explore a cifra de César (no caso a família de cifras ROTXX, em que a cifra de César é a ROT3)
  - Tenha particular atenção à reprodução de padrões do texto em claro
    - Frequência de palavras com uma letra
    - Letras mais frequentes
    - Bigramas
    - Trigramas
- Uma outra cifra muito usada é o ROT13. Experimente cifrar um texto e de seguida cifrar o resultado da primeira cifra. O que obteve? Porquê?



# Cifras Poli-alfabéticas

---

- Aplicação cíclica e sucessiva de várias cifras mono-alfabéticas
  - Usam N alfabetos de substituição
    - Escondem melhor a frequência das letras individuais, digramas e trigramas
  - Exemplo: Cifra de Vigenère
    - <https://calculareconverter.com.br/cifra-de-vigenere-tradutor/>
    - <https://www.dcode.fr/vigenere-cipher>
    - <http://www.numaboa.com.br/criptografia/substituicoes/polialfabeticas/506-vigenere>
  - Problemas
    - Conhecido o período, podem ser criptanalisadas tal como as mono-alfabéticas
    - O período pode ser descoberto usando estatística
-



# Cifra de Vigenère

|   | a | b | c | d | e | f | g | h | i | j | k | l | m | n | o | p | q | r | s | t | u | v | w | x | y | z |
|---|---|---|---|---|---|---|---|---|---|---|---|---|---|---|---|---|---|---|---|---|---|---|---|---|---|---|
| a | A | B | C | D | E | F | G | H | I | J | K | L | M | N | O | P | Q | R | S | T | U | V | W | X | Y | Z |
| b | B | C | D | E | F | G | H | I | J | K | L | M | N | O | P | Q | R | S | T | U | V | W | X | Y | Z | A |
| c | C | D | E | F | G | H | I | J | K | L | M | N | O | P | Q | R | S | T | U | V | W | X | Y | Z | A | B |
| d | D | E | F | G | H | I | J | K | L | M | N | O | P | Q | R | S | T | U | V | W | X | Y | Z | A | B | C |
| e | E | F | G | H | I | J | K | L | M | N | O | P | Q | R | S | T | U | V | W | X | Y | Z | A | B | C | D |
| f | F | G | H | I | J | K | L | M | N | O | P | Q | R | S | T | U | V | W | X | Y | Z | A | B | C | D | E |
| g | G | H | I | J | K | L | M | N | O | P | Q | R | S | T | U | V | W | X | Y | Z | A | B | C | D | E | F |
| h | H | I | J | K | L | M | N | O | P | Q | R | S | T | U | V | W | X | Y | Z | A | B | C | D | E | F | G |
| i | I | J | K | L | M | N | O | P | Q | R | S | T | U | V | W | X | Y | Z | A | B | C | D | E | F | G | H |
| j | J | K | L | M | N | O | P | Q | R | S | T | U | V | W | X | Y | Z | A | B | C | D | E | F | G | H | I |
| k | K | L | M | N | O | P | Q | R | S | T | U | V | W | X | Y | Z | A | B | C | D | E | F | G | H | I | J |
| l | L | M | N | O | P | Q | R | S | T | U | V | W | X | Y | Z | A | B | C | D | E | F | G | H | I | J | K |
| m | M | N | O | P | Q | R | S | T | U | V | W | X | Y | Z | A | B | C | D | E | F | G | H | I | J | K | L |
| n | N | O | P | Q | R | S | T | U | V | W | X | Y | Z | A | B | C | D | E | F | G | H | I | J | K | L | M |
| o | O | P | Q | R | S | T | U | V | W | X | Y | Z | A | B | C | D | E | F | G | H | I | J | K | L | M | N |
| p | P | Q | R | S | T | U | V | W | X | Y | Z | A | B | C | D | E | F | G | H | I | J | K | L | M | N | O |
| q | Q | R | S | T | U | V | W | X | Y | Z | A | B | C | D | E | F | G | H | I | J | K | L | M | N | O | P |
| r | R | S | T | U | V | W | X | Y | Z | A | B | C | D | E | F | G | H | I | J | K | L | M | N | O | P | Q |
| s | S | T | U | V | W | X | Y | Z | A | B | C | D | E | F | G | H | I | J | K | L | M | N | O | P | Q | R |
| t | T | U | V | W | X | Y | Z | A | B | C | D | E | F | G | H | I | J | K | L | M | N | O | P | Q | R | S |
| u | U | V | W | X | Y | Z | A | B | C | D | E | F | G | H | I | J | K | L | M | N | O | P | Q | R | S | T |
| v | V | W | X | Y | Z | A | B | C | D | E | F | G | H | I | J | K | L | M | N | O | P | Q | R | S | T | U |
| w | W | X | Y | Z | A | B | C | D | E | F | G | H | I | J | K | L | M | N | O | P | Q | R | S | T | U | V |
| x | X | Y | Z | A | B | C | D | E | F | G | H | I | J | K | L | M | N | O | P | Q | R | S | T | U | V | W |
| y | Y | Z | A | B | C | D | E | F | G | H | I | J | K | L | M | N | O | P | Q | R | S | T | U | V | W | X |
| z | Z | A | B | C | D | E | F | G | H | I | J | K | L | M | N | O | P | Q | R | S | T | U | V | W | X | Y |

- Exemplo da cifra da letra M com a chave S, originando o criptograma E



# Cifra de Vigenère: Exemplo

---

- Texto = “Eles não sabem que o sonho é uma constante da vida”
- Cifra com o quadrado de Vigenère e chave “poema”
  - Texto: elesnaosabemqueosonhoeumaconstanteda vida
  - Chave: poemapoemapoemapoemapoemapoemapoema
  - Cptgr: tzienpcwmbtaugedgszhdsyyarcetpbxqdpj mpa





# Lab3

---

- Usando o JcryptTool, explore a cifra de Vigenére.
  - Continua a ser fácil descobrir os padrões do texto em claro?
- Cifre um texto, mais ou menos longo usando uma chave de dois caracteres. O que diz sobre a reprodução no criptograma dos padrões do texto em claro?
- Cifre o mesmo texto usando uma chave com 8 caracteres diferentes. Como fica a reprodução de padrões do texto em claro?



# One-Time Pad (Folha de utilização única)

- Folha de papel com uma chave que consiste numa sequência aleatória de números
  - Duas cópias: uma no emissor e outra no recetor
  - Para cifrar, a primeira letra do texto em claro é deslocada uma posição tantas vezes quantas o primeiro número na folha de papel
    - Sucessivamente para as restantes letras
    - Cifra contínua
- Totalmente seguro, desde que:
  - A sequência de números seja realmente aleatória
  - A sequência de números tenha comprimento maior, ou igual, que a mensagem a cifrar
  - Não haja reutilização da chave
- Dado um qualquer criptograma e um qualquer texto em claro da mesma dimensão existe uma chave que transforma um no outro.
- Difícil de operacionalizar, nomeadamente transmitir chaves
  - <https://cryptomuseum.com/crypto/otp/index.htm>
  - Exemplo de como uma cifra teoricamente perfeita não funciona na prática





# Lab4

---

- Com o JcryptTool, use a cifra de Vigenère para cifrar a palavra “AGUEDA” usando a chave “ESCOLA”? Trata-se de uma cifra perfeita?
- Decifre o criptograma usando a chave “EDSKXM”. O que obtêm?



# Princípio de Kirckhoffs

---

- O criptanalista possui um grande número de criptogramas gerados com um determinado algoritmo e chave
  - Os criptogramas não são secretos
- Os criptanalistas conhecem parte dos textos originais
  - É normal haver alguma noção do texto original
  - Ataques com texto conhecido
  - Ataques com texto escolhido
- Não basear a segurança na ocultação (security by obscurity)
  - O criptanalista conhece o algoritmo
- A segurança de um sistema deve depender exclusivamente do segredo da chave



# Princípios de Shannon

---

- Confusão
  - A relação entre o texto em claro, uma chave e o criptograma resultante devem ser a mais complexa possível
- Difusão
  - Uma pequena alteração no texto em claro deve provocar grandes alterações no criptograma
    - Cada pedaço de informação no criptograma deve depender sempre de um pedaço grande de informação em claro
    - Cada bit de informação do texto original deverá influenciar diversos bits do criptograma



# Robustez Criptográfica

---

- Robustez dos algoritmos (a sua resistência a ataques)
  - Ninguém consegue avaliar a robustez de forma precisa
  - São robustos até que alguém os quebre
  - Existem orientações públicas sobre o que deve/não deve ser usado
    - Antecipar problemas futuros
- Algoritmos públicos e sem ataques conhecidos, supostamente são mais robustos
  - Mais investigadores à procura de fraquezas



# Robustez criptográfica: fatores

---

- Espaço de chaves (keyspace)
  - Conjunto de todas as chaves possíveis
  - Determinado pelo tamanho das chaves
    - Quanto maior o tamanho das chaves, mais chaves pode haver
  - Ataque por força bruta tenta com todas as chaves possíveis
  - Algoritmos com maior espaço de chaves são tendencialmente mais robustos
- Fator de trabalho (work factor)
  - Medida subjetivo do tempo e e esforço necessário para realizar as operações
  - Se o fator de trabalho for baixo, a taxa a que as chaves podem ser testadas é alta
    - Implica espaços de chaves grandes
  - Normalmente são introduzidas ineficiências nos algoritmos para aumentar o fator de trabalho



# Criptografia: Serviços

---

- Confidencialidade
    - A informação apenas é lida por quem é suposto poder lê-la
  - Integridade
    - Proteção da informação contra alterações ilegítimas
  - Autenticação
    - Provar a identidade. Que alguém, ou alguma coisa, é quem diz ser
  - Não repúdio
    - Garantir que quem produziu uma informação não o consegue negar
  - Autenticidade
    - Garantir que uma informação é autêntica, i.e., que está íntegra e foi produzida pela entidade correta
-





# Cifras Modernas: Tipos

- Quanto ao tipo de chave
  - Simétricas (chave secreta ou segredo partilhado)
  - Assimétricas (chave pública)
- Quanto à operação
  - Contínuas (poli-alfabéticas)
  - Por blocos (mono-alfabéticas)
- Combinatória

|                     | <i>Por blocos</i> | <i>Contínuas</i> |
|---------------------|-------------------|------------------|
| <i>Simétricas</i>   |                   |                  |
| <i>Assimétricas</i> |                   |                  |



# Criptografia Simétrica

---

- Criptografia que utiliza apenas uma chave
  - A mesma chave para cifrar e para decifrar
  - Se quem cifra não é quem decifra, implica a partilha da chave por dois ou mais interlocutores
- Fornece confidencialidade
- Fornece autenticação limitada
  - MAC: Message Authentication Code



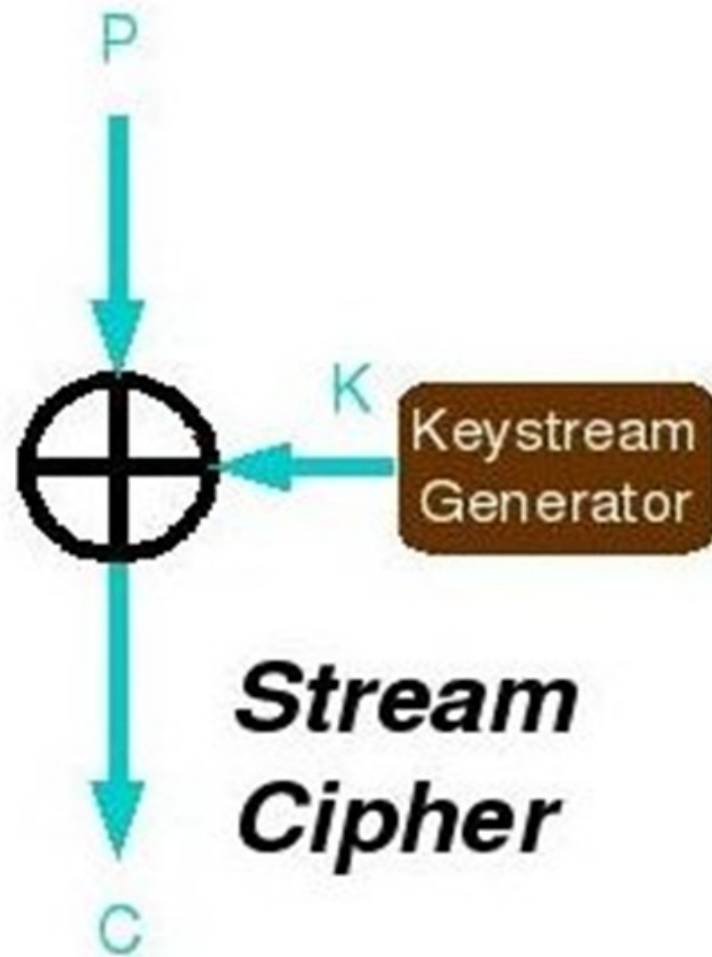
# Cifras Contínuas

---

- Não têm Difusão. Apenas Confusão
- Algoritmos mais comuns
  - A5/1 (US, Europe), A5/2 (GSM)
  - RC4 (802.11 WEP/TKIP, etc.)
  - E0 (Bluetooth BR/EDR)
  - SEAL (c/ acesso aleatório uniforme)
  - Chacha20
  - Salsa20



# Cifras Contínuas



- Motivação
  - Ter cifras próximas de uma one-time-pad
  - Facilidade de realização com computadores
- Mistura de uma chave contínua (*keystream*) com o texto ou criptograma
  - Usando uma função facilmente invertível, tipicamente a função XOR



# Função XOR (Ou-exclusivo)

---

- Função binária que aplicada em duas strings de bits, produz uma terceira string, de acordo com a regra:
  - Se dois bits são diferentes, o resultado é 1
  - Se dois bits são iguais, o resultado é zero
- Tabela:
  - $0 \oplus 0 = 0$
  - $0 \oplus 1 = 1$
  - $1 \oplus 0 = 1$
  - $1 \oplus 1 = 0$
- Utiliza-se em vez da substituição de caracteres
- Também designada como soma de módulo 2



# Cifras contínuas

---

- Geração e mistura da chave contínua
  - Geradores: pseudo aleatórios
    - Baseados em shift-registers, cifras por blocos, famílias de funções, etc.
  - Mistura: XOR dígito a dígito ( $C = T \oplus K$ ;  $T = C \oplus K$ )
    - Na prática é feita bit a bit, ou byte a byte



# Cifras Contínuas: Segurança Prática

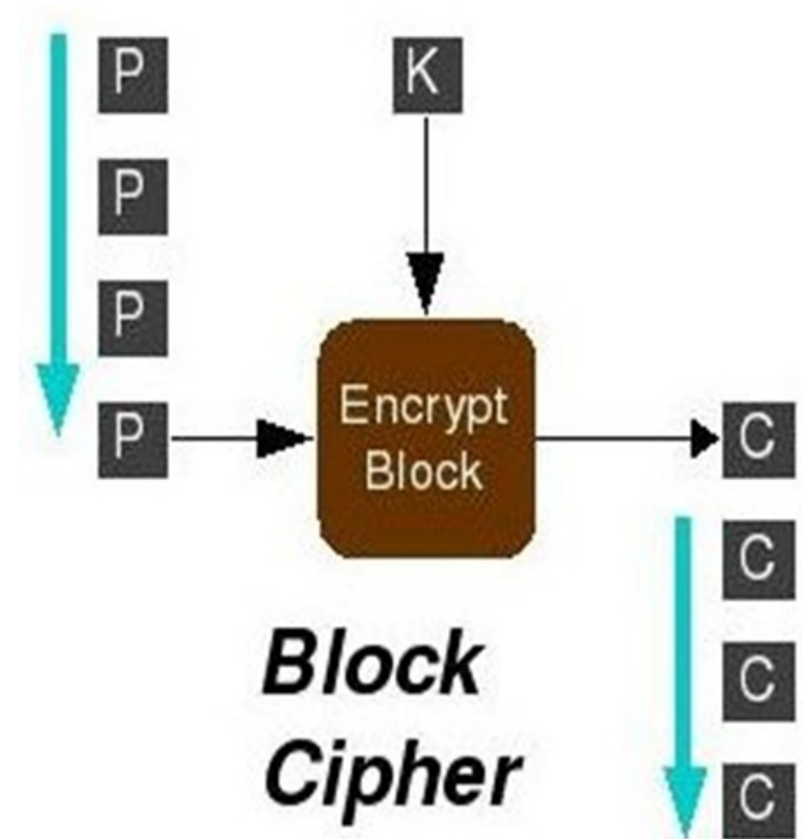
---

- O texto a cifrar deverá ser inferior ao período da chave contínua
  - A repetição de ciclos facilita a criptanálise se se conhecer o período e amostras do texto original
  - A exposição da chave contínua é total caso se conheça o texto e o criptograma
- As chaves contínuas não devem ser reutilizadas
  - $C = A \oplus K$
  - $C' = B \oplus K$
  - $C \oplus C' = A \oplus K \oplus B \oplus K = A \oplus B$
- Tem de existir controlo de integridade
  - É fácil alterar o criptograma de forma determinística



# Cifras Simétricas por Blocos

- Cifra Mono-alfabética
- Difusão e confusão
- A mensagem é dividida em blocos de grande dimensão
  - Processamento (operações de cifra e decifra) bloco a bloco
  - Cada bloco é processado de forma independente dos restantes
- Algoritmos mais usados
  - DES (Data Encryption Standard)
    - Tamanho do bloco = 64;
    - Tamanho da chave = 56.
  - IDEA (International Data Encryption Algorithm)
    - Tamanho do bloco = 64;
    - Tamanho da chave = 128.
  - AES (Advanced Encryption Standard, aka Rijndael)
    - Tamanho do bloco = 128;
    - Tamanho da chave = 128, 192 ou 256.
  - Outros (Blowfish, CAST, RC5, etc.)







# DES (Data Encryption Standard)

---

- Adotado nos EUA como padrão federal (1976)
  - Blocos de 64 bits
  - Chaves de 56 bits
    - Tem chaves fracas (4), semi-fracas (12) e quasi-fracas (48)
      - Fáceis de identificar
  - Difusão e Confusão
  - Ataques conhecidos
    - Pesquisa exaustiva é técnica e economicamente viável
  - **Não deve ser usado!**
-



# Triple-DES

---

- Para reforçar o algoritmo DES
  - Publicada em 1998
- Cifra tripla: **Triple-DES (EDE)**
  - Cifra de um texto  $T_i$ 
    - $C_i = E_{K1}(D_{K2}(E_{K3}(T_i)))$
  - Decifra de um criptograma  $C_i$ 
    - $T_i = D_{K3}(E_{K2}(D_{K1}(C_i)))$
  - Normalmente usa-se  $K1=K3$ 
    - Se  $K1=K2=K3$  transforma-se numa cifra simples
- **Não deve ser usado!**



# AES – Advanced Encryption Standard

---

- Adotado nos EUA como padrão federal (2002)
- Blocos de 128 bits
- Três tamanhos de chave:
  - 128 bits
  - 192 bits
  - 256 bits
- Difusão e Confusão



# Tratamento do sub-bloco final

---

- O sub-bloco final pode ter um tamanho menor que o tamanho do bloco definido pelo algoritmo de cifra em uso. O que fazer?
- Alinhamento com excipiente (padding)
  - Introduz símbolos adicionais até perfazer o tamanho do bloco
  - Os símbolos adicionais são removidos após a operação de decifra
  - Aumenta o criptograma face ao texto original
  - Algoritmo PKCS#7 Padding
    - Completa bloco com bytes com o nº de bytes em falta
    - Não faltar nenhum byte, corresponde a faltar um bloco completo
    - PKCS#5 Padding, é uma versão anterior definida apenas para blocos de 8 bytes
- Na cifra contínua não existe este problema porque não há blocos
  - A cifra é feita símbolo a símbolo



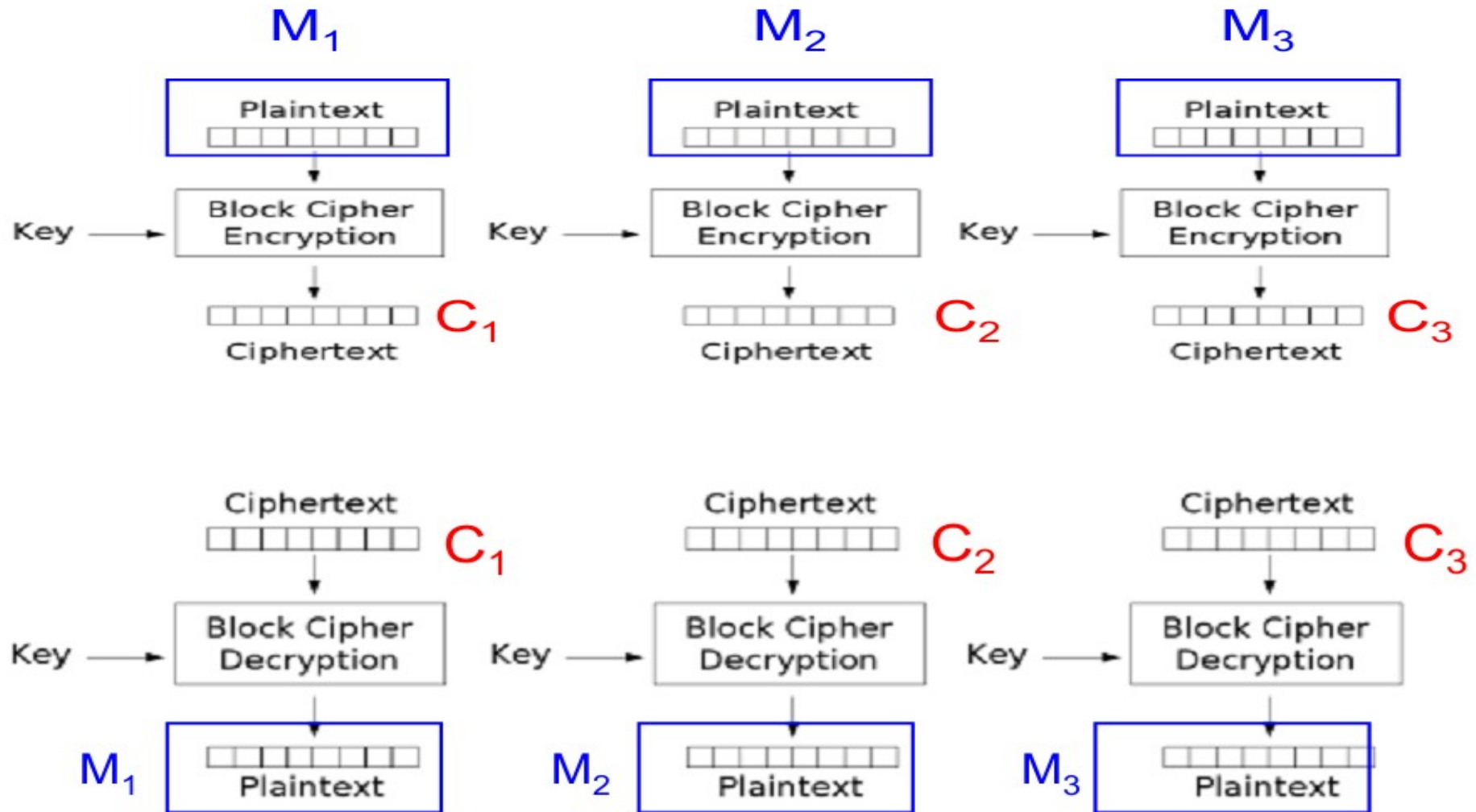
# Modos de Cifra: ECB (Electronic Code Book) (1)

---

- É o modo de cifra mais simples
- A mensagem em claro é partida em blocos independentes, contíguos e de tamanho fixo, sendo cada bloco cifrado isoladamente
- A mensagem cifrada é obtida pela concatenação dos blocos cifrados



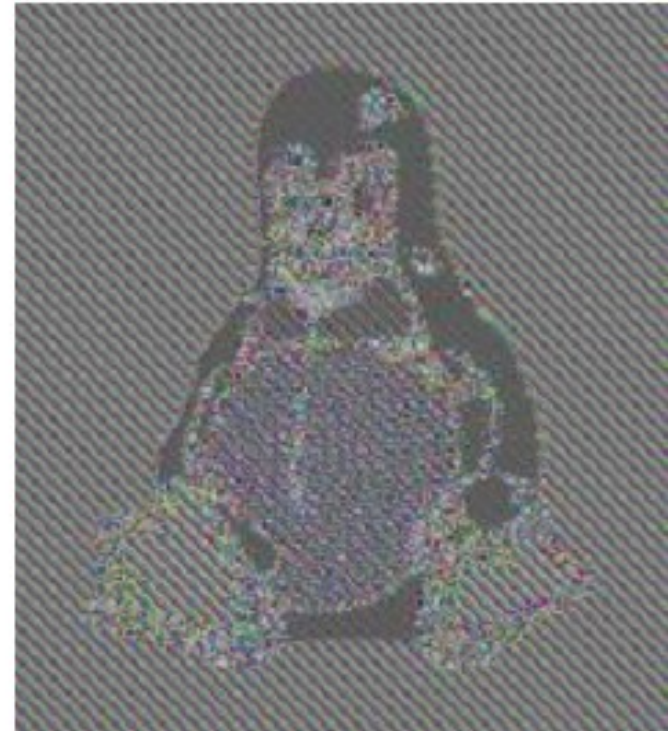
# Modos de Cifra: ECB (2)





# Modos de Cifra: ECB (3)

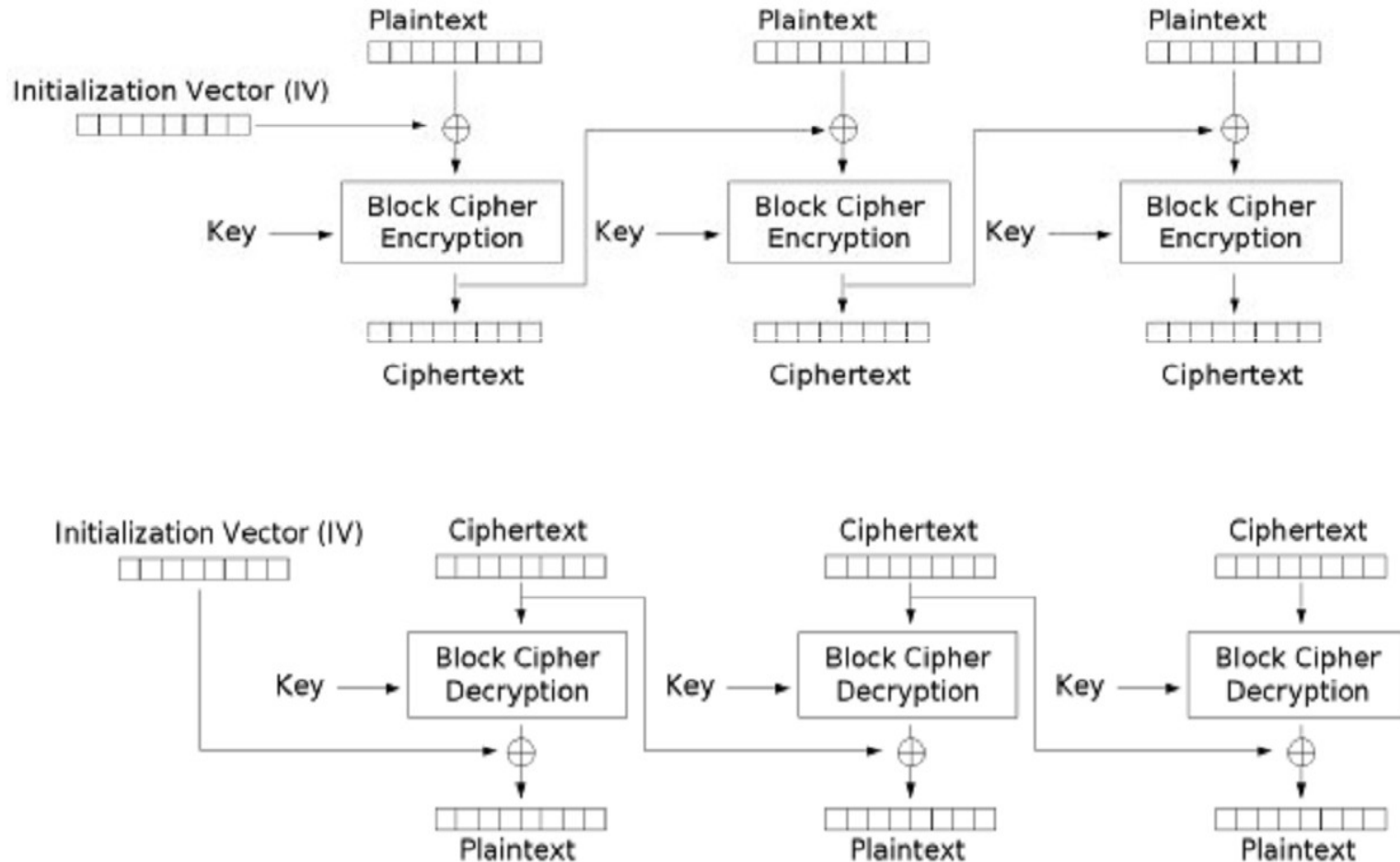
---



- Blocos de texto em claro iguais produzem blocos de criptograma iguais (cifra monoalfabética).
  - Não esconde o padrão dos dados
-



# Modos de Cifra: CBC (Cipher Block Chaining) (1)



- Necessário um Vector de Inicialização (IV), normalmente público, utilizado para a soma com o primeiro bloco.

- O recetor tem que conhecer o seu valor





# Modos de Cifra: CBC (3)



- Reduz substancialmente a replicação de padrões devido à introdução de feedback
  - Dois blocos iguais de texto em claro geram dois blocos diferentes de criptograma



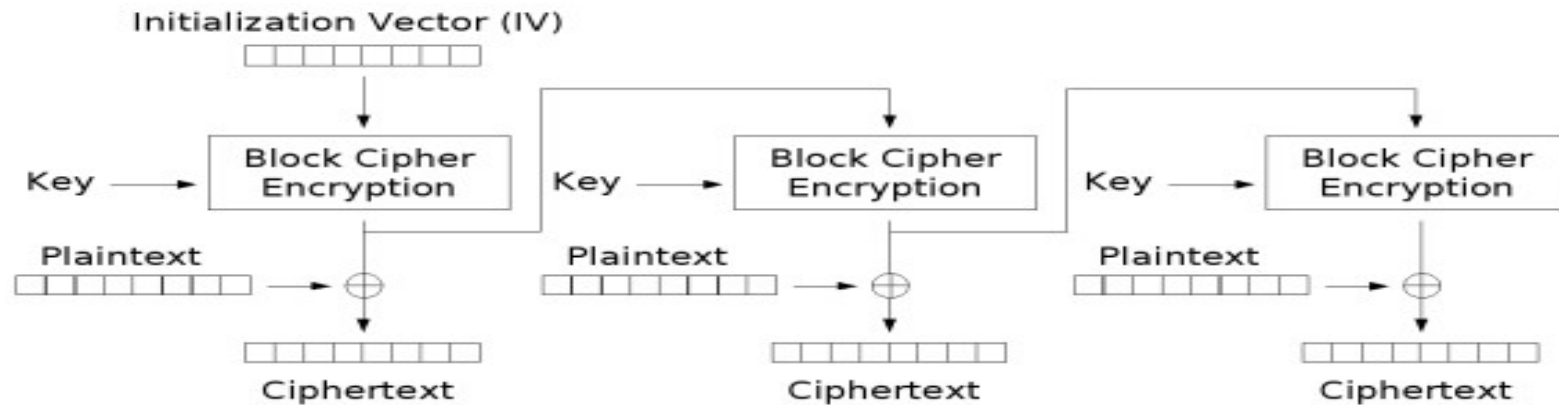
# Modos de Cifra: OFB, CFB e CTR

---

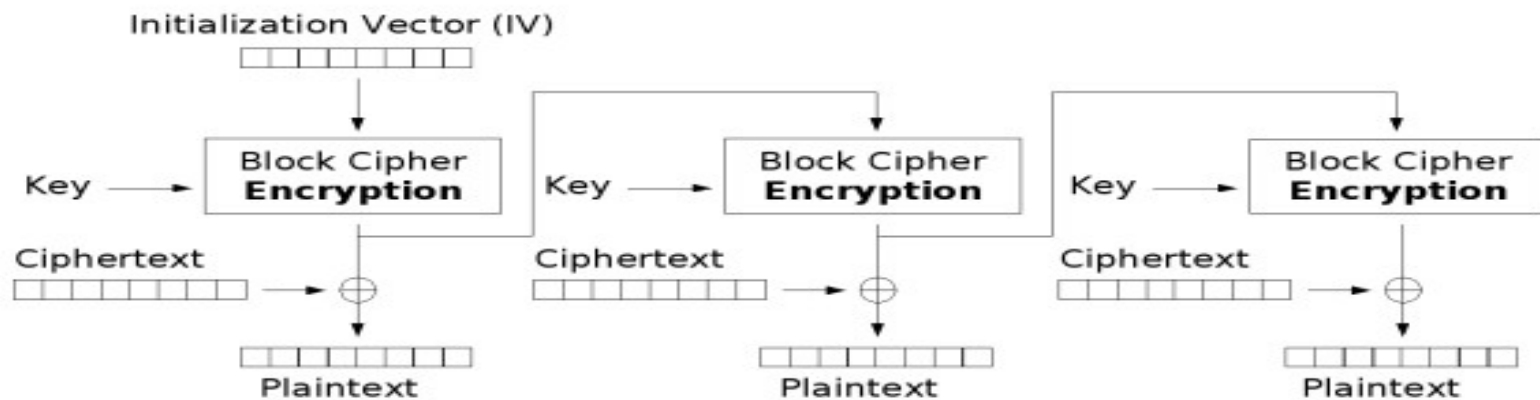
- A cifra é feita símbolo a símbolo e não bloco a bloco
- Transformam uma cifra por blocos numa cifra contínua
  - O gerador de chave contínua é constituído por uma função de cifra por blocos
- OFB: O gerador de chave é alimentado com a saída do gerador de chave na operação anterior
- CFB: O gerador de chave é alimentado com o criptograma produzido na operação anterior
- CTR: O gerador de chave é alimentado por um contador adicionado ao vetor inicial



# Modos de Cifra: OFB (*Output Feedback*)



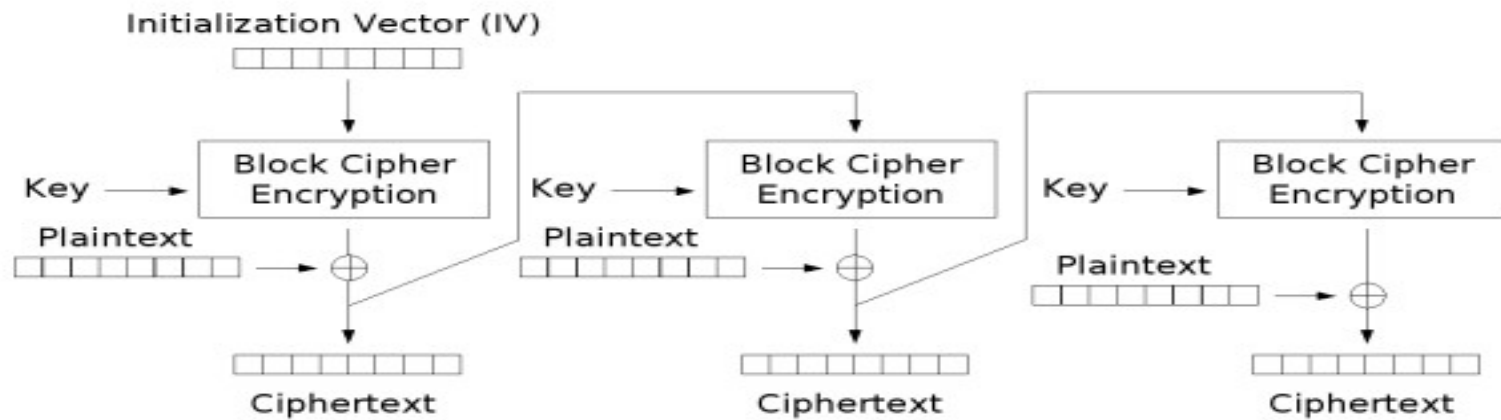
Output Feedback (OFB) mode encryption



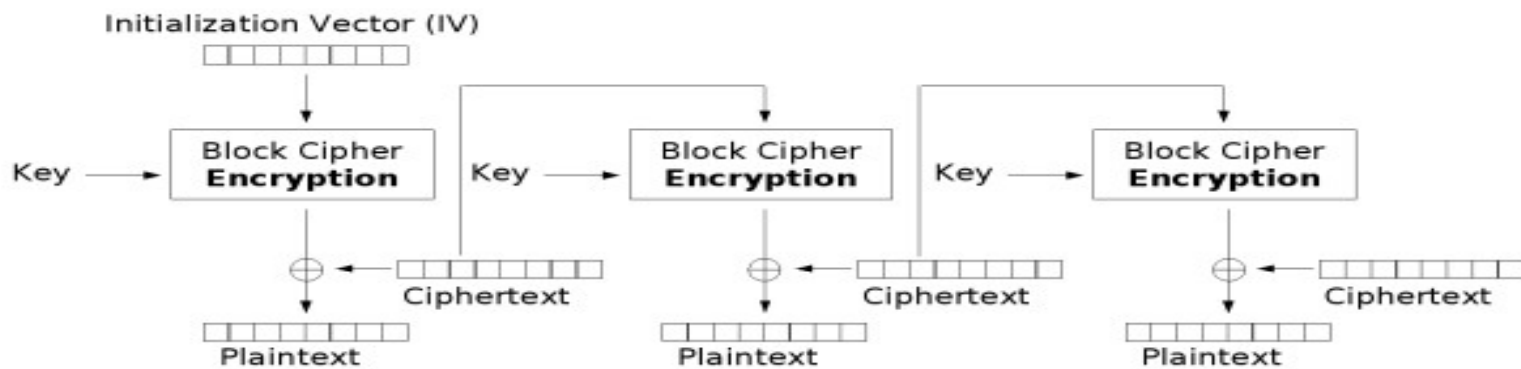
Output Feedback (OFB) mode decryption



# Modos de Cifra: CFB (*Cipher Feedback*)



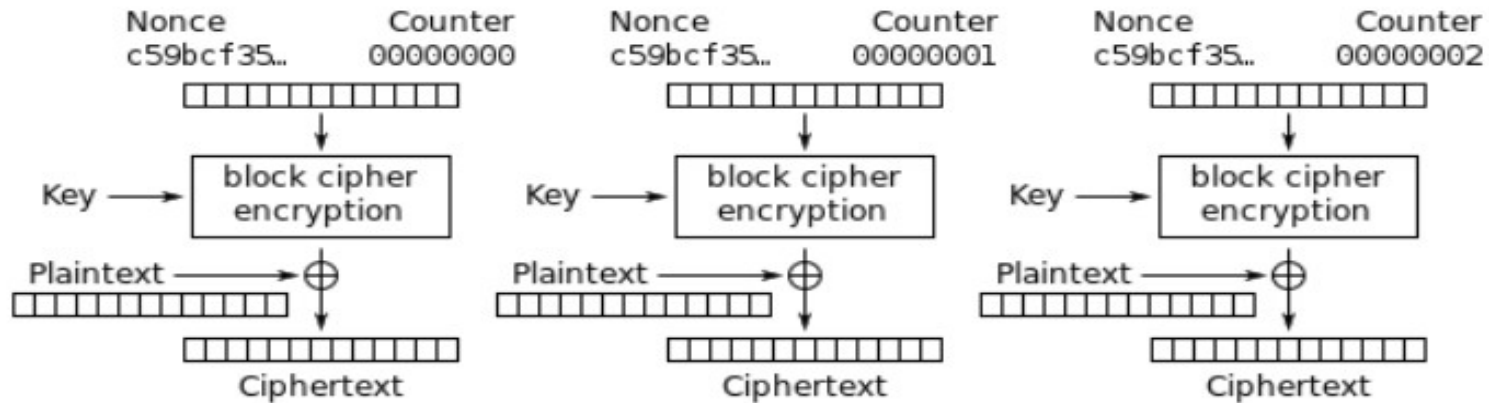
Cipher Feedback (CFB) mode encryption



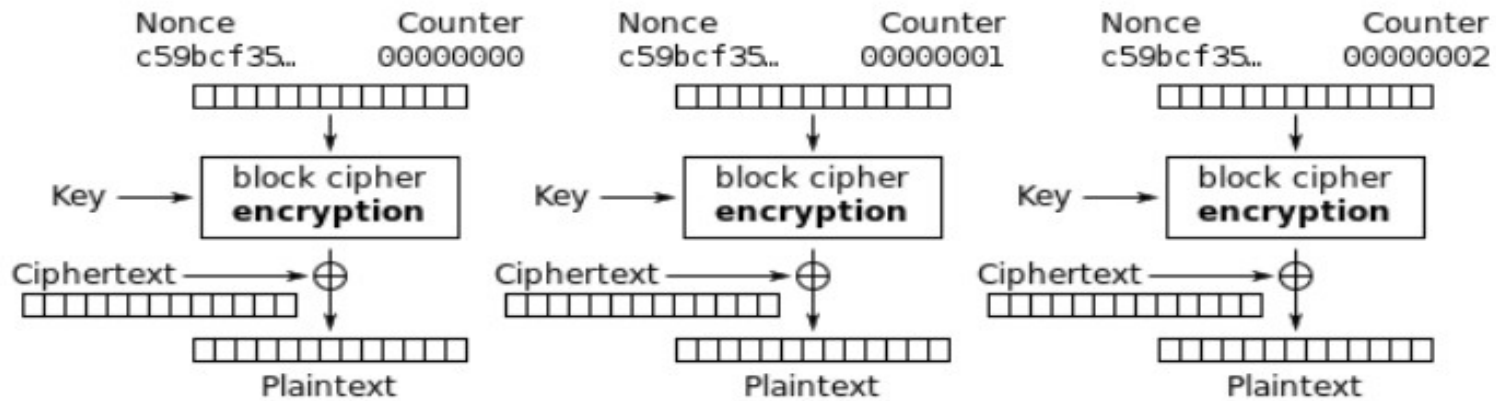
Cipher Feedback (CFB) mode decryption



# Modos de Cifra: CTR (*Counter*)



Counter (CTR) mode encryption

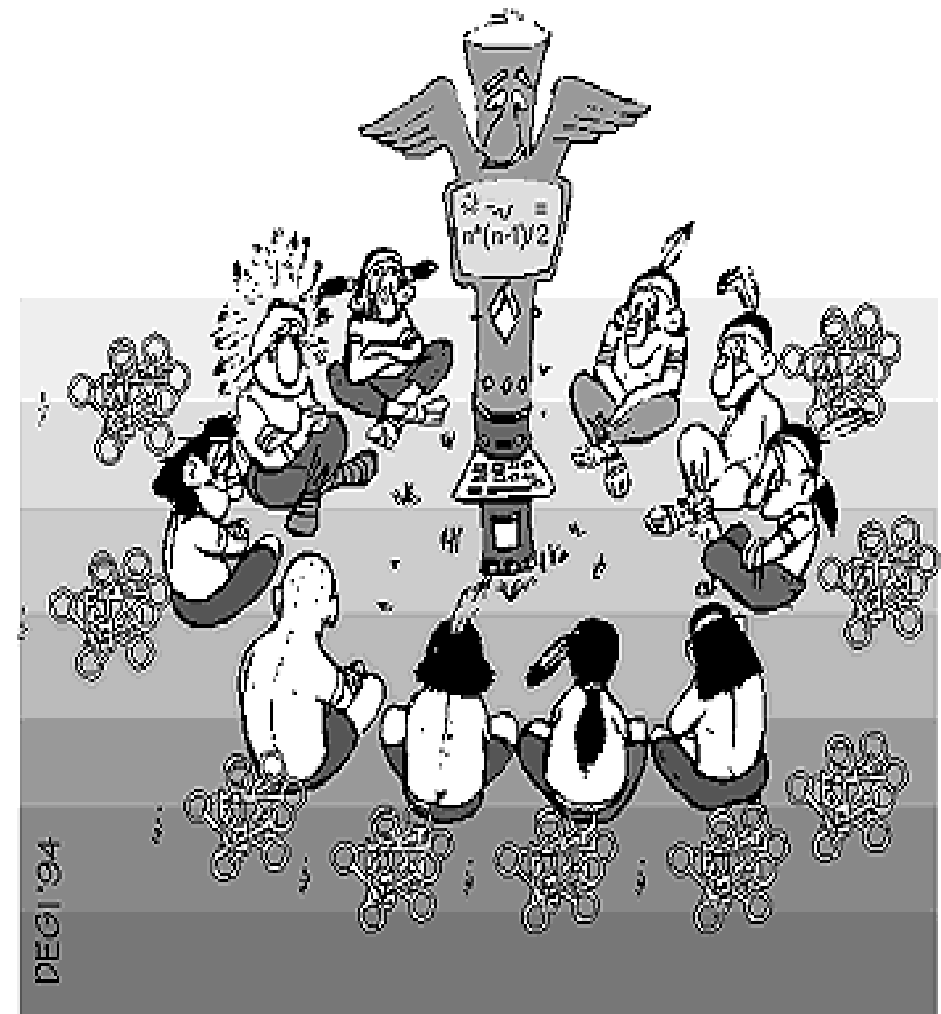


Counter (CTR) mode decryption



# Criptografia Simétrica (2)

- Vantagens
  - Desempenho
    - Normalmente muito eficientes
  - Difícil de quebrar (chaves longas)
- Desvantagens
  - Número de chaves
    - N interlocutores, comunicação secreta 2 a 2 =>  $N \times (N-1)/2$  chaves
    - Não é escalável
- Problemas
  - Distribuição de chaves inerentemente insegura





# Criptografia Assimétrica (1)

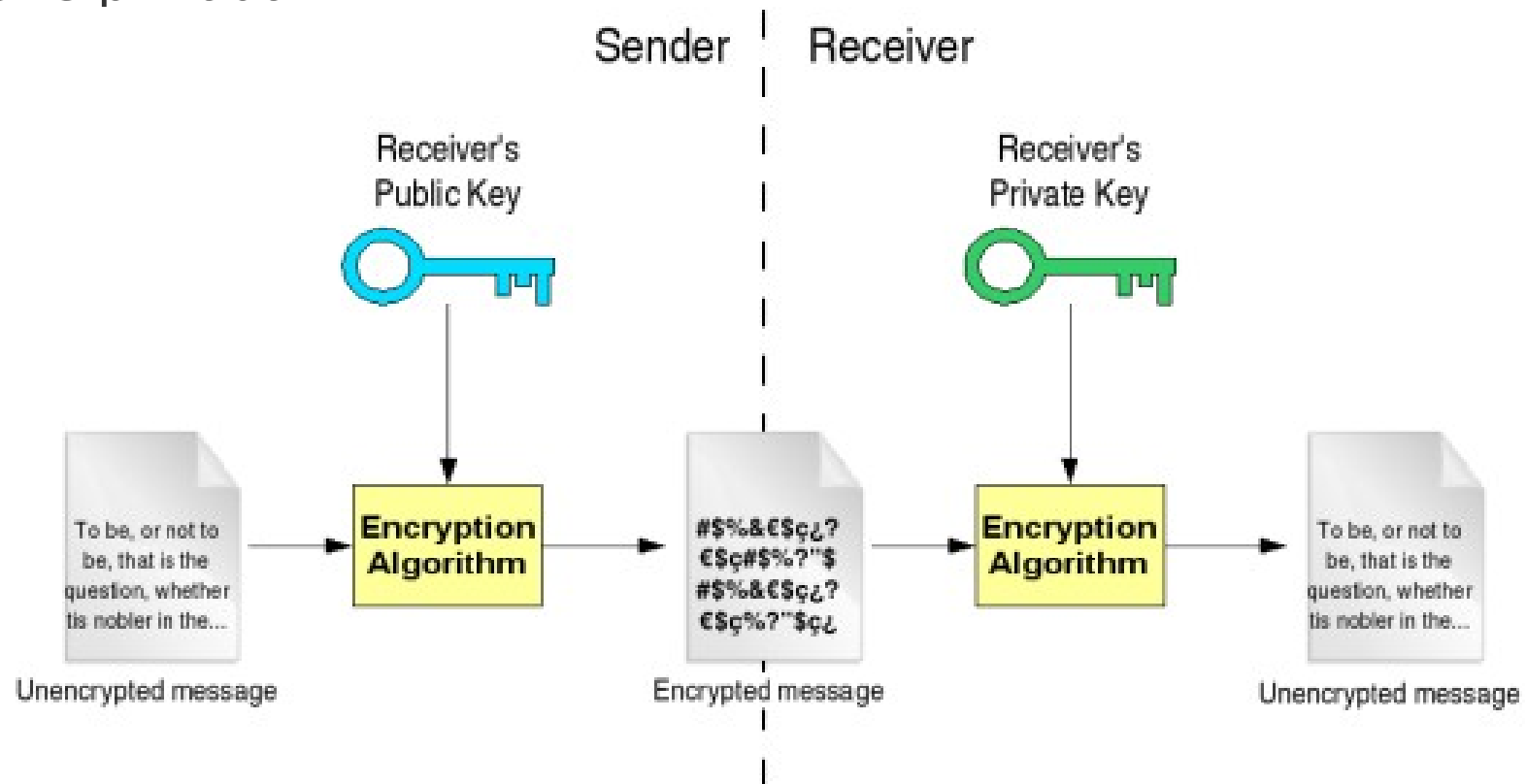
- Também designada por criptografia de chave pública
- Usa um **par de chaves**
  - Matematicamente relacionadas entre si
  - O que uma chave cifra, a outra decifra
  - Uma chave privada
    - Pessoal e intransmissível
  - Outra pública
    - Livremente distribuída
  - Não é possível determinar a chave privada a partir da chave pública
- A segurança na utilização destas cifras depende do secretismo da chave privada





# Cifra Assimétrica

- A mensagem é cifrada usando a chave pública do destinatário
- Apenas o destinatário pode decifrar a mensagem, usando a sua chave privada.







# Criptografia Assimétrica (2)

---

- Baseia-se na complexidade matemática
  - Algoritmos mais usados
    - RSA ( $C = M^e \bmod n$ ;  $M = C^d \bmod n$ )
      - Tamanhos das chaves: 1024, 2048, 3072, 4096, ...
      - Chave deve ser de pelo menos 2048 bits
      - Vídeo 5.8
    - ElGamal
    - Curvas elípticas
  - Vantagens
    - Um par de chaves por interlocutor
      - N interlocutores => N pares de chaves
  - Desvantagens
    - Desempenho (normalmente pouco eficientes)
-



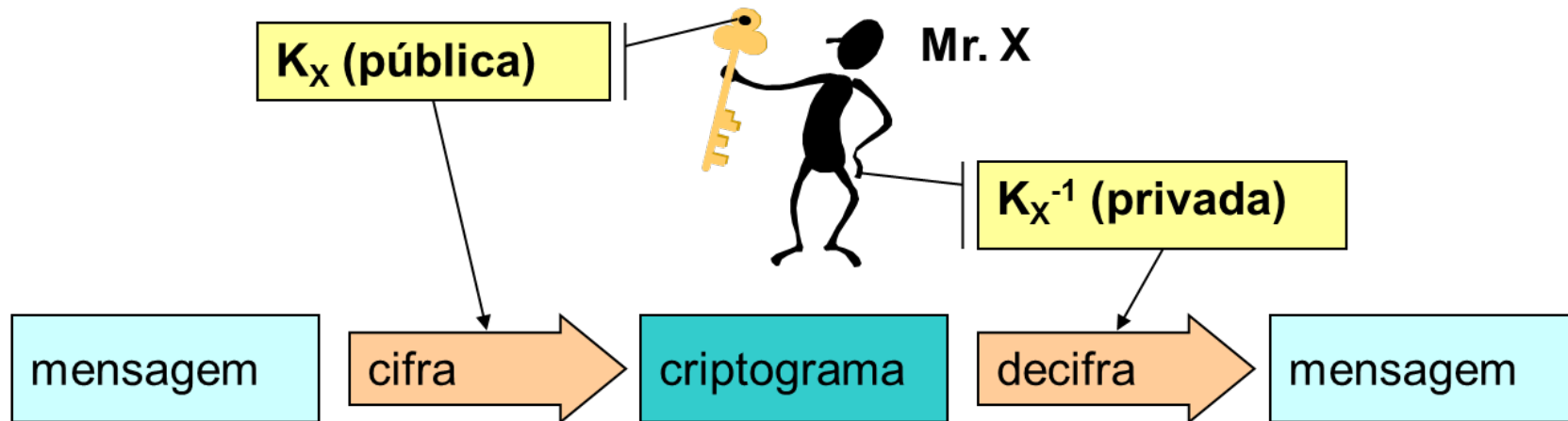
# Criptografia Assimétrica (3)

---

- Serviços fornecidos:
  - Confidencialidade
    - Sem necessidade de troca de segredos
  - Integridade dos dados
  - Autenticação da origem/autoria (assinaturas digitais)
  - Não-repúdio da origem/autoria (assinaturas digitais)
- Problemas
  - Distribuição de chaves públicas
  - Tempo de vida dos pares de chaves



# Criptografia Assimétrica: Confidencialidade



- Para comunicar confidencialmente com Mr. X basta conhecer a sua chave pública  $K_x^+$ 
  - Cifra-se a mensagem usando a chave pública do Mr. X:  $K_x^+$ 
    - $C = E(K_x^+, P)$
  - Só Mr. X consegue decifrar o criptograma, usando a sua chave privada:  $K_x^-$ 
    - $P = D(K_x^-, C)$
- Não há autenticação
  - Mr. X não sabe quem produziu o criptograma
  - Se  $K_x^+$  for verdadeiramente pública, qualquer um o pôde fazer

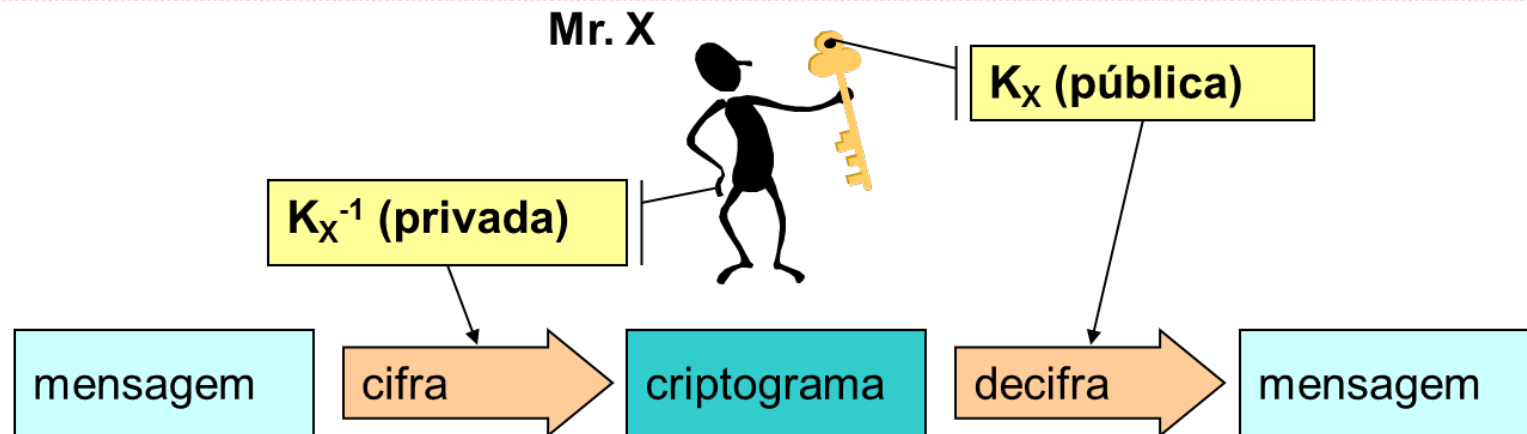


# Cifra Híbrida

- Cifras são ferramentas que devem ser utilizadas e combinadas para resolver o problema em mãos.
- Como fazer para enviar, de forma confidencial, um ficheiro a um destinatário?
- Problemas
  - Cifra assimétrica: utilização não é eficiente em computadores, pelo que não pode ser usada para cifrar ficheiros
  - Cifra simétrica: a distribuição de chaves é difícil
- Vantagens
  - Cifra assimétrica: não há segredos na distribuição de chaves
  - Cifra simétrica: utilização muito eficiente em computadores
- Solução?
  - Cifrar o ficheiro usando cifra simétrica com uma chave gerada na hora
  - Cifrar a chave simétrica usando cifra assimétrica e a chave pública do destinatário



# Criptografia Assimétrica: Autenticação

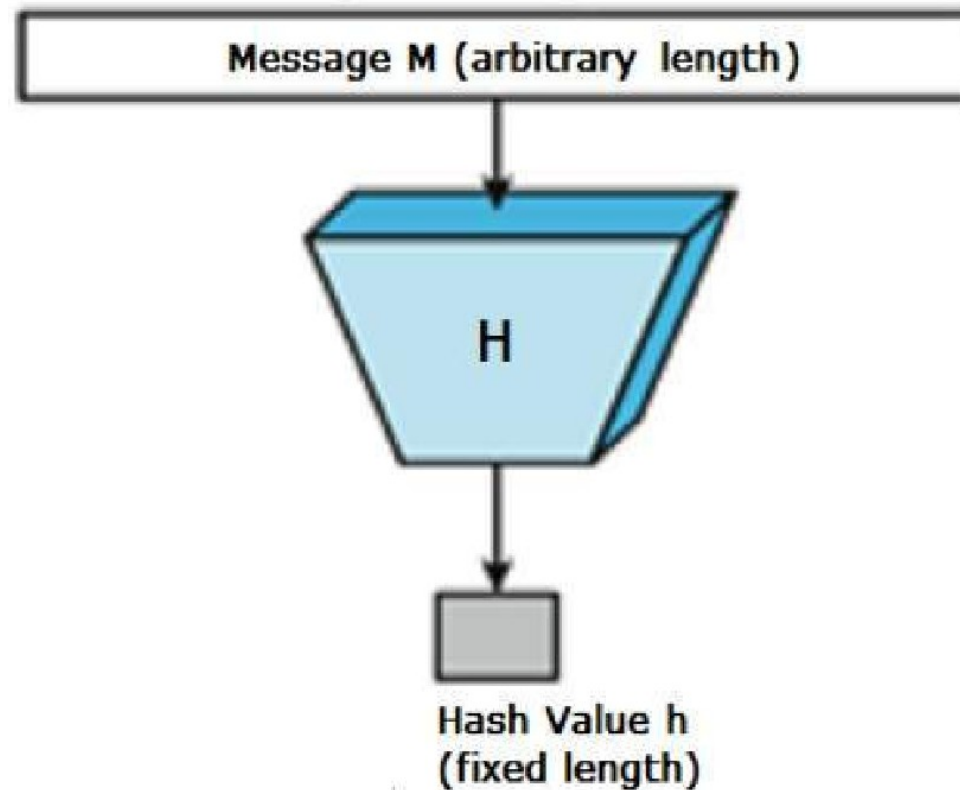


- Mr. X cifra a mensagem (cria o criptograma) usando a sua chave privada:  $K_X^{-1}$ 
  - Só Mr. X conhece a chave privada  $K_X^{-1}$  com que foi gerado o criptograma
  - Todos podem verificar que foi MR. X que gerou o criptograma decifrando-o usando a chave pública de Mr. X:  $K_X$
  - Se houver alteração do criptograma, a chave pública do Mr. X não conseguirá decifrá-lo.
    - Logo, a mensagem não é autêntica, i.e., não foi produzida pelo Mr. X
- Não há confidencialidade
  - $K_X$  é pública. Quem a conhecer pode decifrar o criptograma
  - Se  $K_X$  for verdadeiramente pública, qualquer um o pôde fazer



# Funções Criptográficas de Hash (Funções de Síntese)

- Produzem valores de dimensão constante (*digest*) a partir de “textos” de dimensão variável





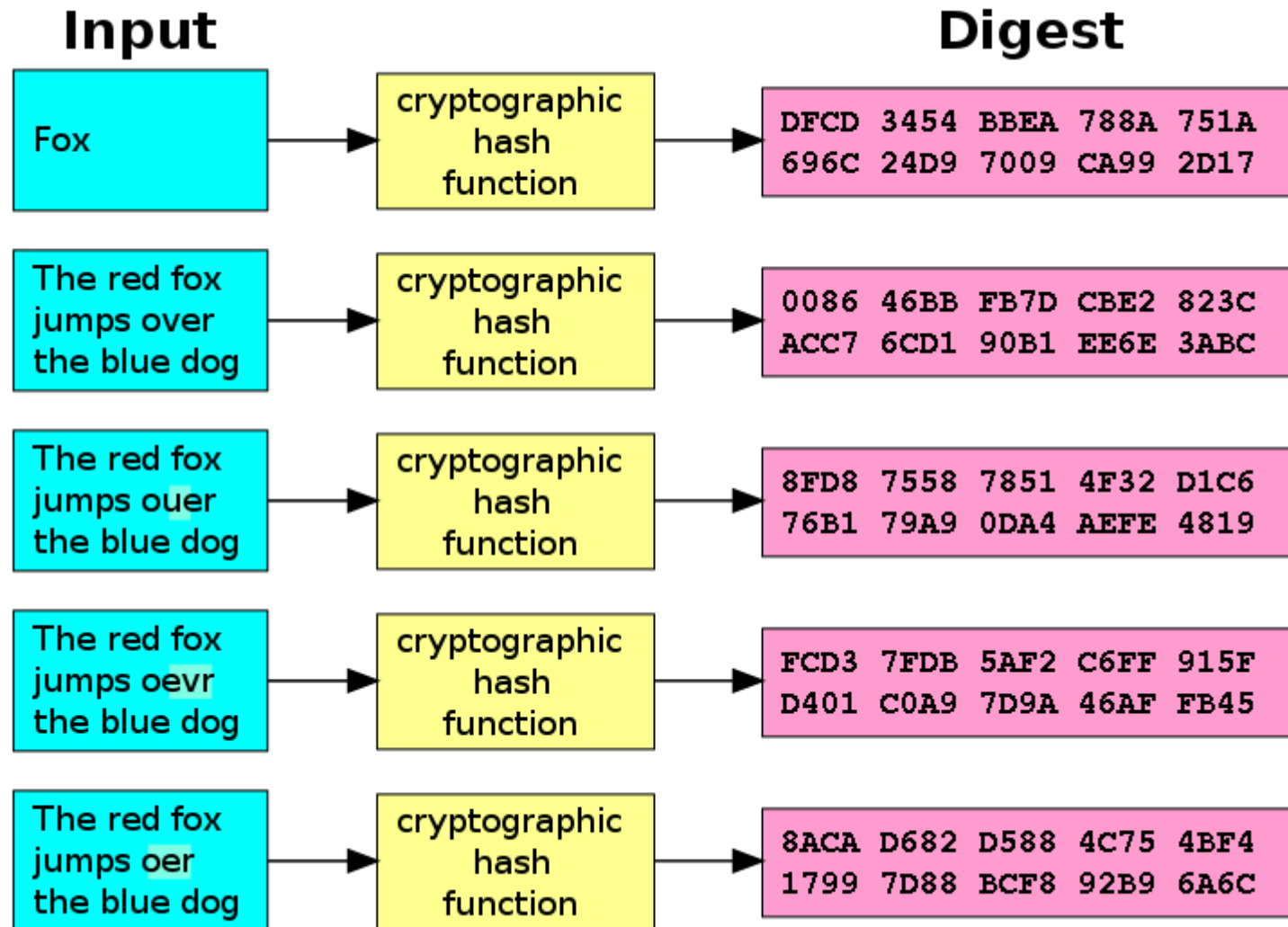
# Funções Criptográficas de Hash (Funções de Síntese)

---

- Produzem valores de dimensão constante (*digest*) a partir de “textos” de dimensão variável
- Propriedades importantes:
  - Difusão: Pequenas alterações na entrada provocam grandes diferenças na saída.
  - São “não invertíveis”:
    - Resistência à descoberta de um texto: Dada uma síntese, é difícil encontrar um texto que a produza
    - Resistência à colisão: É difícil encontrar dois textos diferentes que produzam uma mesma síntese
    - Resistência à descoberta de um 2º texto: Dado um texto e a sua síntese, é difícil encontrar um segundo texto que a produza



# Funções criptográficas de Hash: Difusão







# Sal

---

- Se o texto de entrada para uma função hash não for suficientemente aleatório ou for muito pequeno, e isso for do conhecimento do atacante, pode levar a que este tente descobrir o texto de entrada.
- Sal é um elemento de aleatoriedade que é concatenado com o texto de entrada para impedir as tentativas de ataque atrás indicadas
- Usado por exemplo para guardar passwords



# Funções Criptográficas de Hash

## Algoritmos mais comuns

---

- MD5 (128 bits)
    - Já não é seguro! É fácil descobrir colisões!
  - SHA-1
    - Secure Hash Algorithm 1, 160 bits
    - Já se consegue obter colisões pelo que não é recomendada a sua utilização
  - SHA-2
    - Secure Hash Algorithm 2
    - Vários tamanhos: 224 (SHA-224), 256 (SHA-256), 384 (SHA-384), 512 (SHA-512)
  - SHA-3
    - Secure Hash Algorithm 3 (antes conhecido por keccak)
    - Vários tamanhos: 224 (SHA3-224), 256 (SHA3-256), 384 (SHA3-384), 512 (SHA3-512)
  - RIPEMD
    - RACE Integrity Primitives Evaluation Message Digest
    - 320 bits
-



# Ferramentas

- Linux
  - sha1sum
    - Calcula o hash usando SHA-1
  - shaxxxsum
    - Calcula o hash usando SHA-2
    - xxx deve ser substituído pelo tamanho de hash pretendido
      - Por exemplo: sha256sum calcula um hash de 256 bits
  - openssl
    - Este comando implementa muitas operações criptográficas
    - Para o calculo de hash deve usar-se o sub-comando dgst:
      - `openssl dgst`
      - Mostra os algoritmos suportados: `openssl dgst -list`
      - Calcula hash usando sha3 com 512 bits: `openssl dgst -sha3-512 <filename>`
- Windows
  - HashCalc (softonic)
- Online
  - Vários

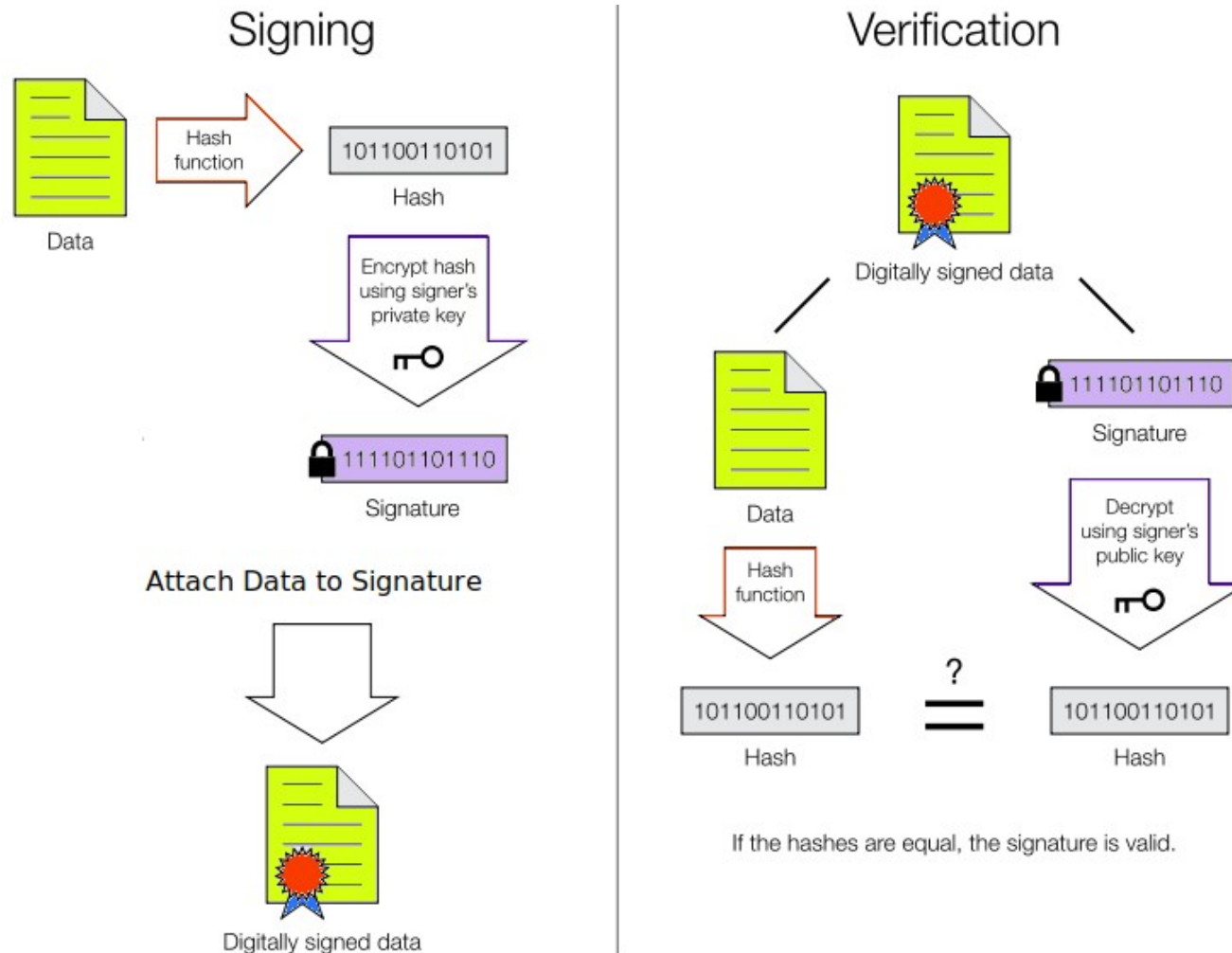


# Assinatura Digital

- Uma assinatura digital é gerada usando a chave privada de um par de chaves assimétricas
  - Só o dono do par de chaves consegue produzir a assinatura
  - Todos os que tenham acesso à correspondente chave pública conseguem validar a assinatura
- Aproximação usada
  - Funções de síntese (hash)
    - Para aumentar o desempenho!
    - Calcula o hash do documento a assinar
  - Criptografia assimétrica
    - Usa a chave privada para assinar o hash do documento a assinar
- Ferramentas Linux
  - openssl
    - Assinatura: `openssl dgst -sha256 -sign privatekey.pem -out data.txt.signature data.txt`
    - Geração do par de chaves: `openssl genrsa -out privatekey.pem 2048`
    - Extração da chave pública: `openssl rsa -in privatekey.pem -outform PEM -pubout -out publickey.pem`
  - gpg
    - Comando usado no guião prático



# Processo de assinatura e verificação





# Autenticadores de Dados

---

- Conjuntos de bits que acompanham uma mensagem e que garantem a sua correção e origem
- Dois tipos:
  - Assinaturas Digitais
    - Usa chaves assimétricas
  - Códigos de Autenticação de Mensagens (MAC - *Message Authentication Code*)
    - Usa chaves simétricas



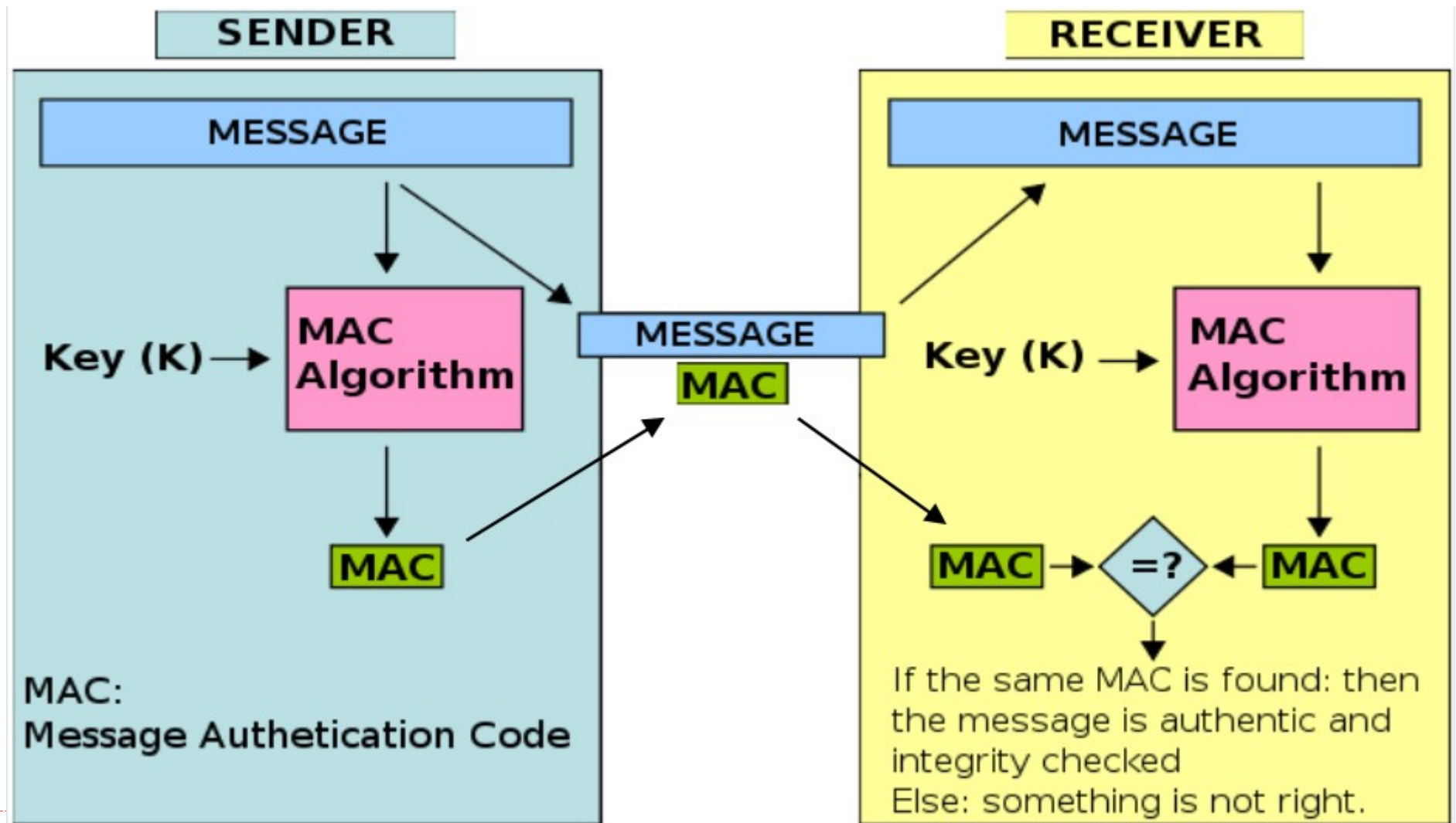
# *Message Authentication Code (MAC)*

---

- Um MAC é gerado com recurso a uma chave simétrica
  - Só os conhecedores da chave conseguem gerar/validar o MAC
- Aproximações
  - Calculando o hash do texto em conjunto com uma chave
    - HashFunction (K, texto, ...)
  - Cifrando uma síntese (hash)
    - Por exemplo, usando uma cifra simétrica por blocos
- Funções:
  - HMAC (dimensão da função de síntese usada)
  - ANSI X9.9 (DES-MAC) com DES CBC (64 bits)



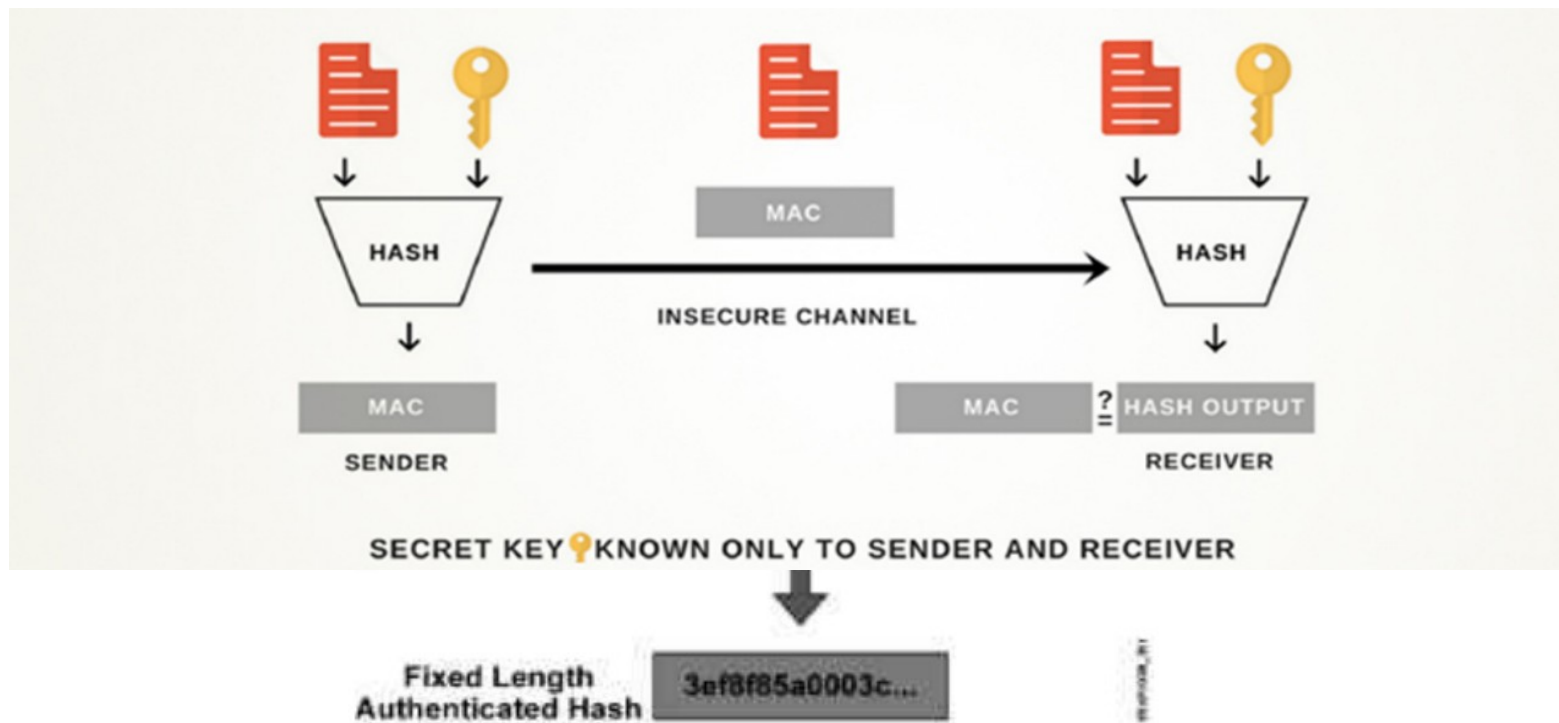
# Utilização de MAC para autenticar mensagens







# HMAC (Hashed MAC)



- Calculo de HMAC
  - [https://asecuritysite.com/mac/openssl\\_hmac](https://asecuritysite.com/mac/openssl_hmac)
  - Linha de comandos (linux): `openssl sha256 -hmac "SECRET" filename`



# *Message Authentication Code (MAC)*

---

- Prova que a mensagem foi produzida por um dos interlocutores
- Será que quem recebe a mensagem consegue provar perante terceiros que o outro enviou a mensagem?
- Não prova, perante terceiros, qual dos interlocutores produziu a mensagem porque ambos poderiam tê-la produzido
  - Ambos conhecem a chave usada



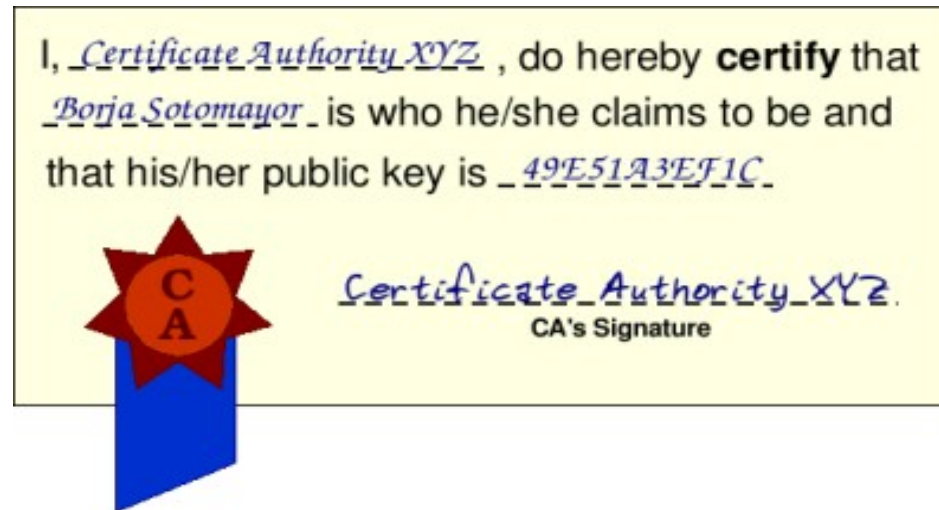
# Assinatura Digital

---

- Permite
    - Garantir a integridade de um documento
      - Está tal como quando foi assinado
    - Autenticar o assinante do documento
      - Assegurar a identidade do criador/originador
    - Assegurar a autenticação perante terceiros
      - Os autores genuínos não podem negar a autoria da assinatura do documento
      - Não repúdio
  - A autenticação e o não-repúdio referem-se a pessoas (entidades)
    - Apenas possíveis quando se tem a certeza sobre o dono da chave pública
    - Como é que se pode saber quem é o dono de uma chave pública?
-



# Certificado Digital de Chave Pública



- Atesta a identidade do dono de uma chave pública
- Documento que distribui uma chave pública de forma segura
  - Contêm a chave pública a distribuir (campo Subject Public Key Info)
  - Identifica a entidade dona da chave pública (campo Subject)
  - Emitido por uma Entidade Certificadora (CA) (campo Issuer)
  - Assinado digitalmente pela Entidade Certificadora (CA) que o emitiu
- Documento público criptograficamente seguro
  - Assinado digitalmente: Não pode ser alterado
  - Pode ser distribuído com segurança através de canais inseguros



# Boas Práticas na Utilização de Chaves Privadas

---

- Os pares de chaves devem ser gerados pelo dono
    - Para assegurar ao máximo que mais ninguém tem acesso à chave privada
    - Este princípio pode ser relaxado se a chave não for para autenticação ou assinaturas digitais
  - A utilização da chave privada deverá ser controlada
    - Proteção com senha
    - Correção das aplicações que a usam
  - Confinamento em dispositivo autónomo
    - O dispositivo gera pares de chaves
    - O dispositivo apenas envia para o exterior a chave pública
      - E nunca a privada
    - Todas as operações envolvendo a chave privada são realizadas no dispositivo
    - Exemplo de dispositivo autónomo: *smartcard*
-



# Smartcard

- Computador de dimensões e capacidade de calculo reduzidas
  - Embutido na superfície de um cartão de dimensões normalizadas
    - Cartão de cidadão
    - Cartões multibanco e cartões de crédito
  - Num token USB





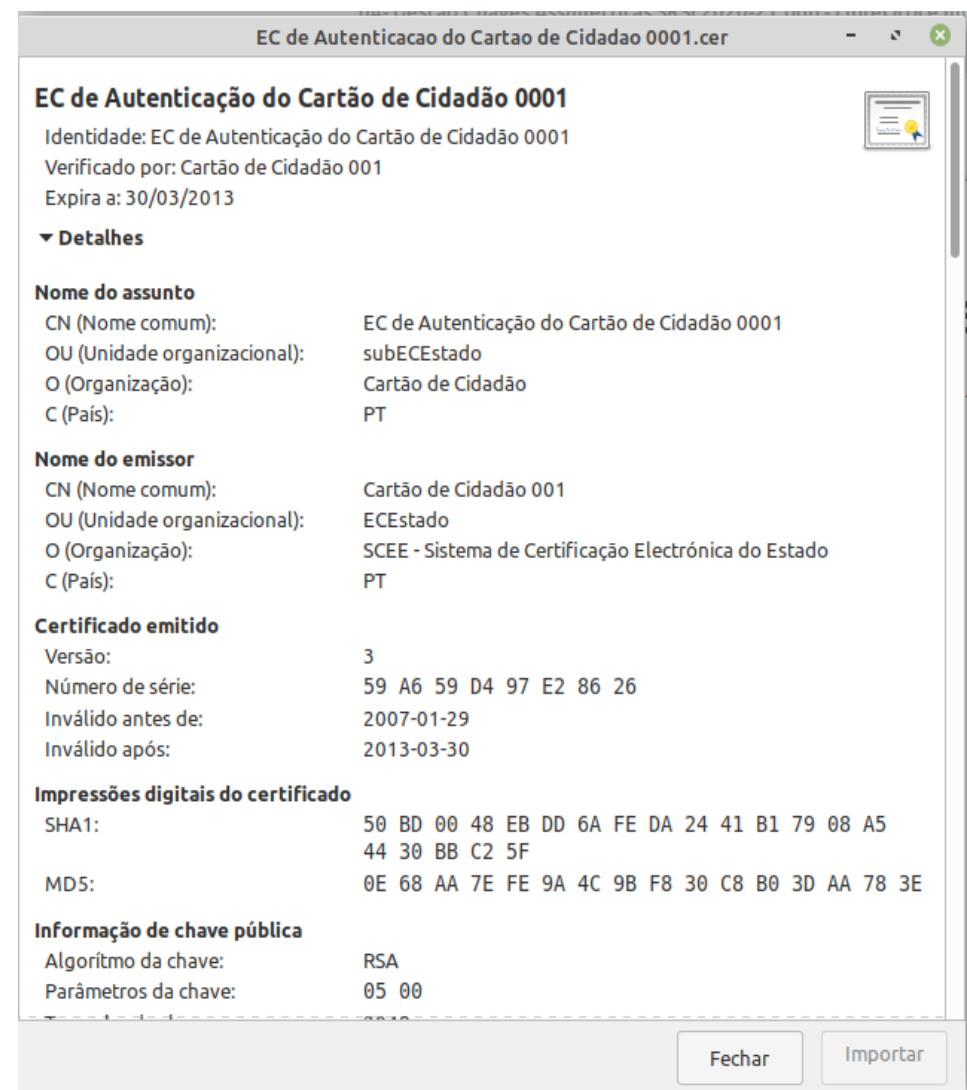
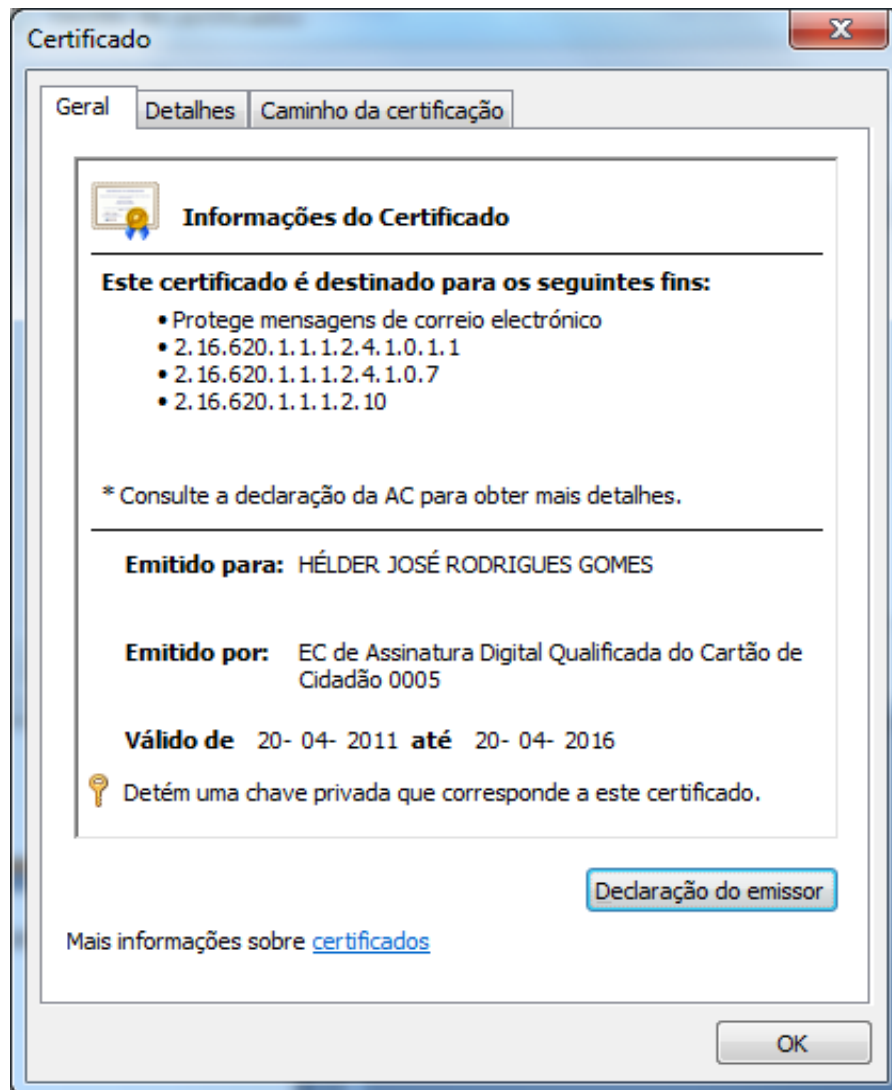
# Gestão de Chaves Públicas

---

- A quem pertence uma determinada chave pública?
  - Importante para:
    - A validação de assinaturas digitais: quem assinou?
    - Cifra: estou efetivamente a usar a chave publica do destinatário?
- Certificados digitais de chave pública
  - Geridos no contexto de uma PKI
    - PKI: Public Key Infrastructure (Infraestrutura de Chave Pública)



# Visualização de Certificados

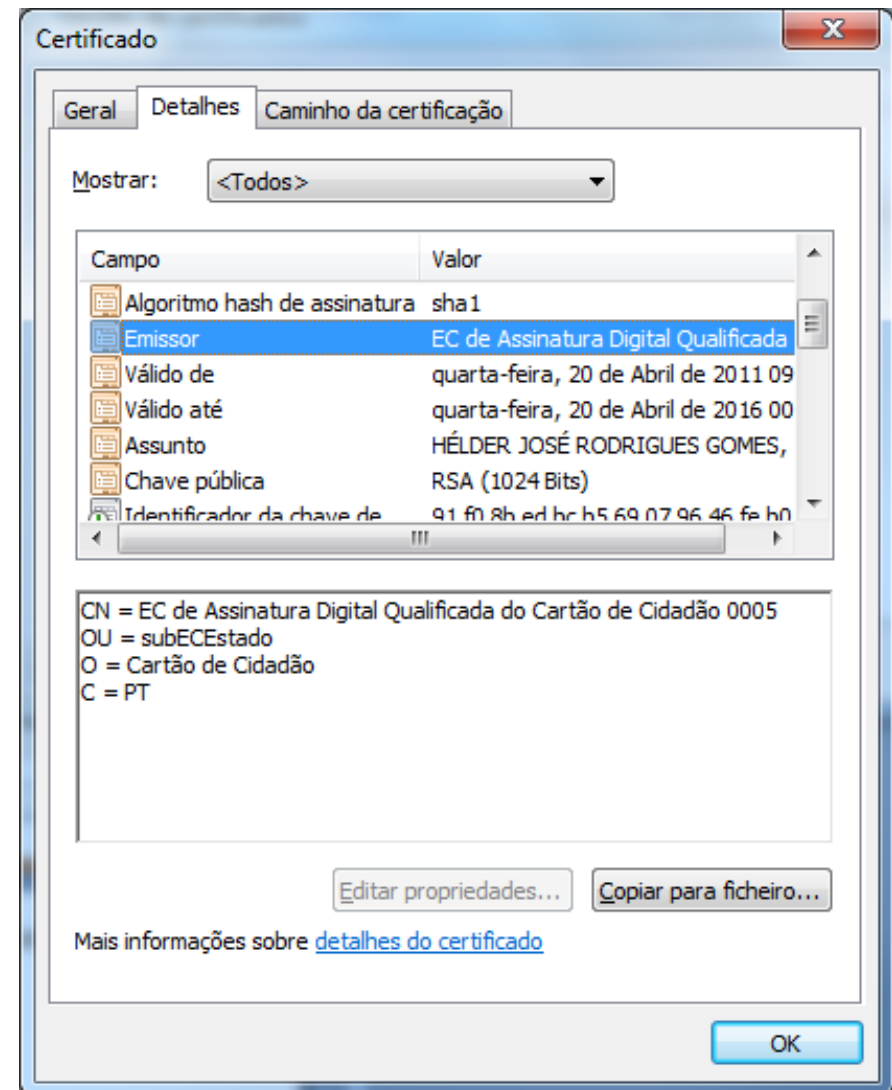






# Formato dos Certificados: X509v3

- Define que dados existem num certificado.
  - Campos
- Campos importantes:
  - Assunto (Subject): Nome da entidade para quem o certificado foi emitido. Tem o formato de distinguished name.
  - Intervalo de validade
  - Chave Pública: Informação sobre a chave pública da entidade para quem o certificado é emitido.
  - Emissor (Issuer): Nome da Entidade Certificadora que emitiu o certificado. Tem o formato de distinguished name.
  - Assinatura digital: o certificado inclui uma assinatura de toda a informação nele contida, gerada usando a chave privada da CA emissora.





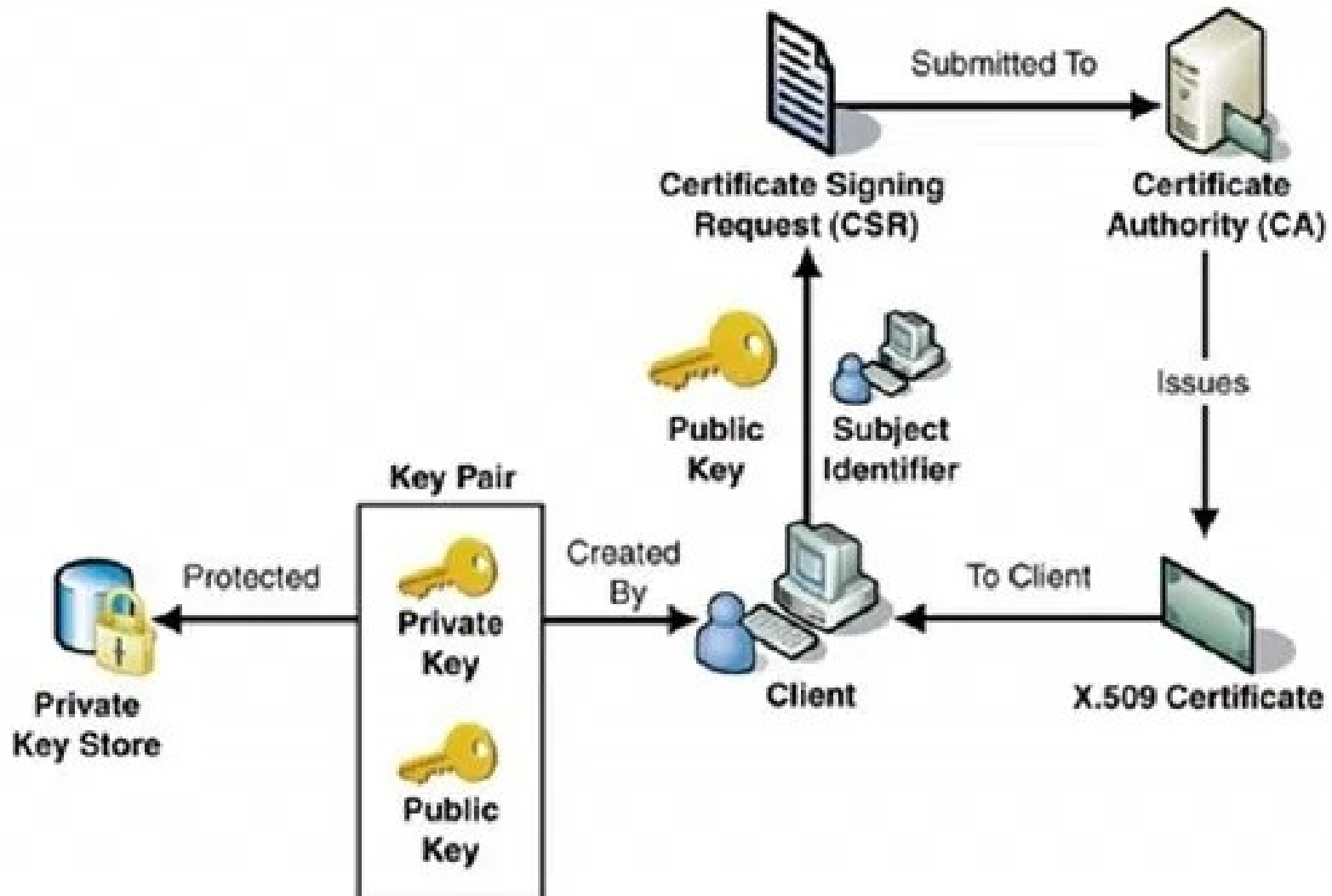
# Emissão de Certificados

---

- Os certificados digitais de chave pública são emitidos por Entidades Certificadoras (CA – Certification authorities)
- O pedido de emissão de certificados é feito através de um Pedido de Assinatura de Certificado (CSR – Certificate Signing Request)
  - Contém a chave pública e dados da entidade dona da chave pública
  - É assinado usando a chave privada
- A emissão do certificado apenas deve ocorrer após a CA confirmar:
  - A identidade da entidade dona da chave pública
  - A efetiva posse da correspondente chave privada



# Pedido e Emissão de Certificados





# Confiança (Trust)

---

- A confiança numa CA implica confiar nos certificados por ela emitidos
- Como um certificado atesta quem é o dono da chave pública no certificado, a confiança na CA permite garantir:
  - Autenticação: Se uma assinatura for validada com a chave pública num certificado, então ela só pode ter sido produzida pela entidade identificada nesse certificado
  - Não-Repúdio: Se uma assinatura for validada com a chave pública num certificado, então a entidade para quem esse certificado foi emitido não pode negar que produziu a assinatura.



# Validação de Certificados

---

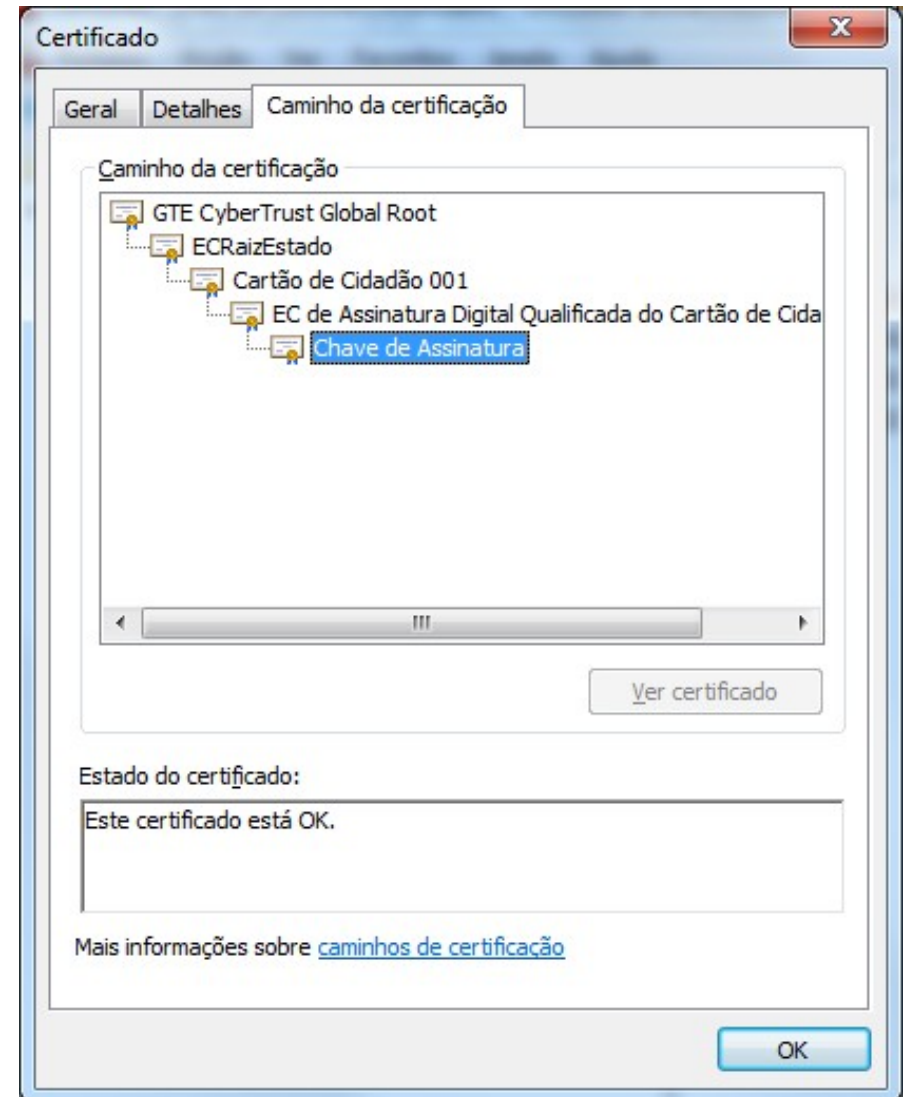
- Um certificado é válido se:
  - Se a sua assinatura digital está válida e foi feita por uma CA de confiança
  - Está dentro do período de validade contido dentro do certificado.
  - Não foi revogado pela CA emissora
  - Está a ser usado dentro do contexto para o qual foi emitido
- Como saber quem assinou o certificado?
  - Necessário certificado da CA que o emitiu
  - Cadeia de certificados (de certificação)



# Cadeia de Certificação

(Certification path or certification chain)

- CA Raiz: O seu certificado é auto assinado.
  - Está no topo da hierarquia.
- CA Intermédia: O seu certificado é assinado por outra CA.
- CA Emissora: Que emite certificados para utilizadores finais





# Transitividade da Confiança

---

- Se confio numa CA, confio:
  - Nos seus processos de gestão do ciclo de vida dos certificados
  - Em todos os certificados por ela emitidos, direta ou indiretamente
    - Transitividade da confiança
- Validação de um certificado de uma entidade
  - Implica o estabelecimento de uma cadeia de certificação desde o certificado a validar até uma CA Raiz
    - O não estabelecimento da cadeia implica que o certificado da entidade não é de confiança (não é válido)
  - Implica a validação das assinaturas digitais em todos os certificados da cadeia de certificação
    - Começando pela Raiz de Confiança



# Certificados Raiz (trust anchor) Rever

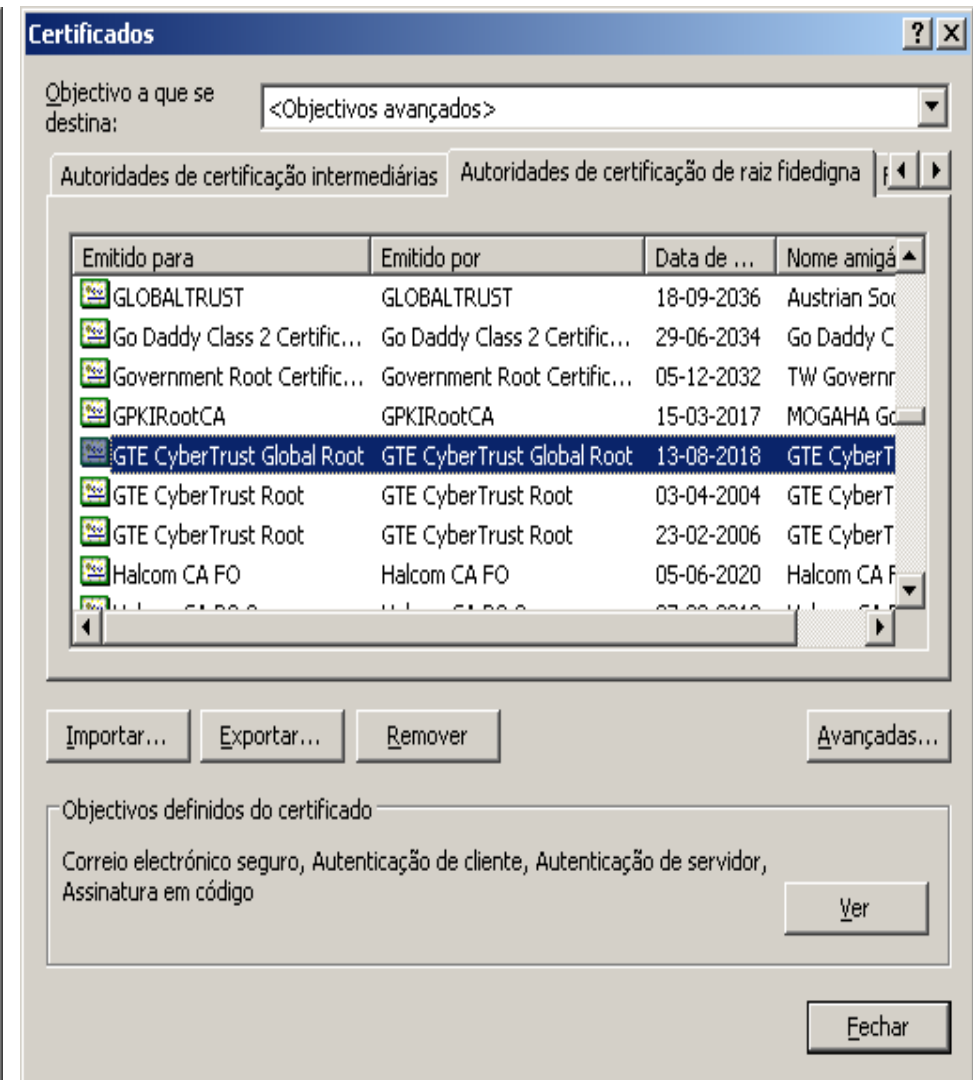
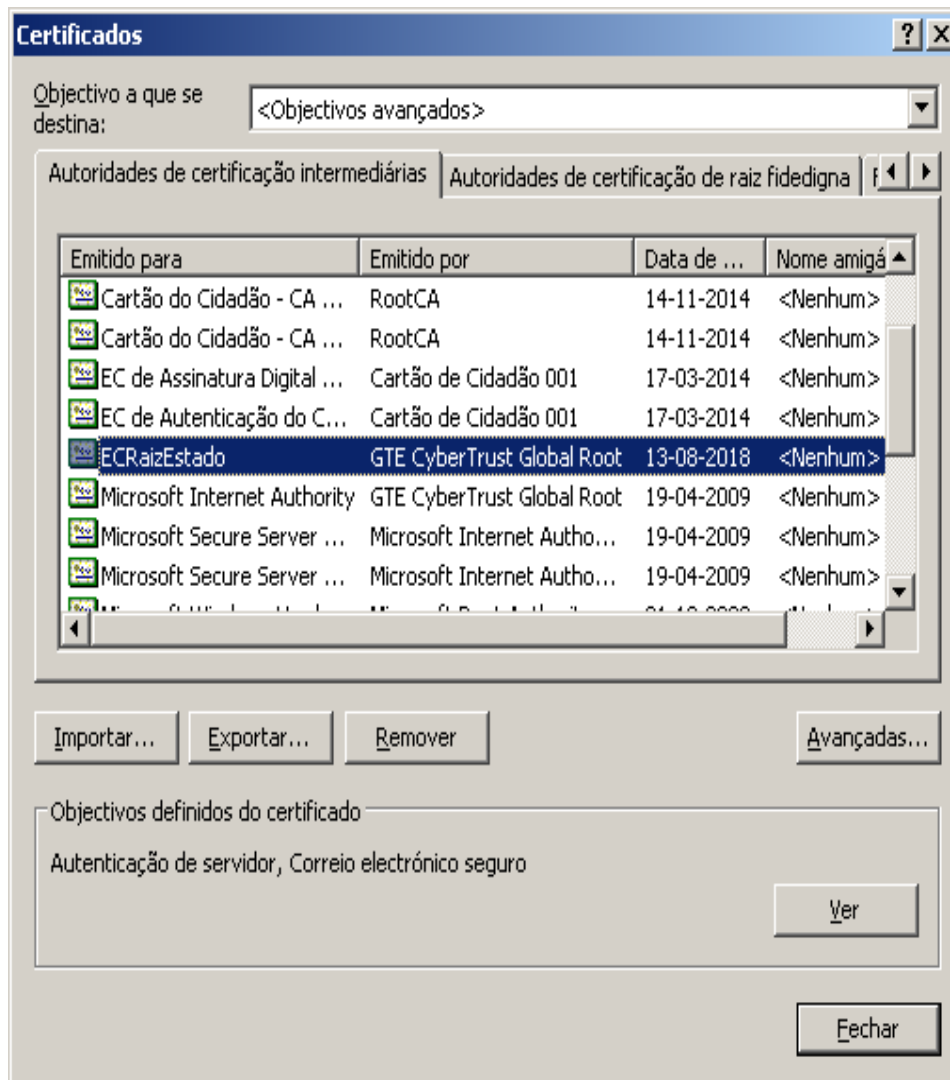
---

- Os Certificados Raiz (root certificates) são aqueles onde o utilizador deposita a sua confiança
  - Âncora de confiança ou raiz de confiança
- São armazenados em arquivos de certificados (certificate stores)
  - Difusão embebida: Vêm com os sistemas operativos ou com aplicações.
    - Firefox e Thunderbird trazem os seus próprios certificados raiz
  - Confiança no sistema operativo, ou numa aplicação, implica confiança nos respetivos certificados embebidos
  - O utilizador pode gerir os certificados de confiança: adicionar, remover.
- Certificate Pinning: certificado hard-coded na aplicação
  - Comum em Apps



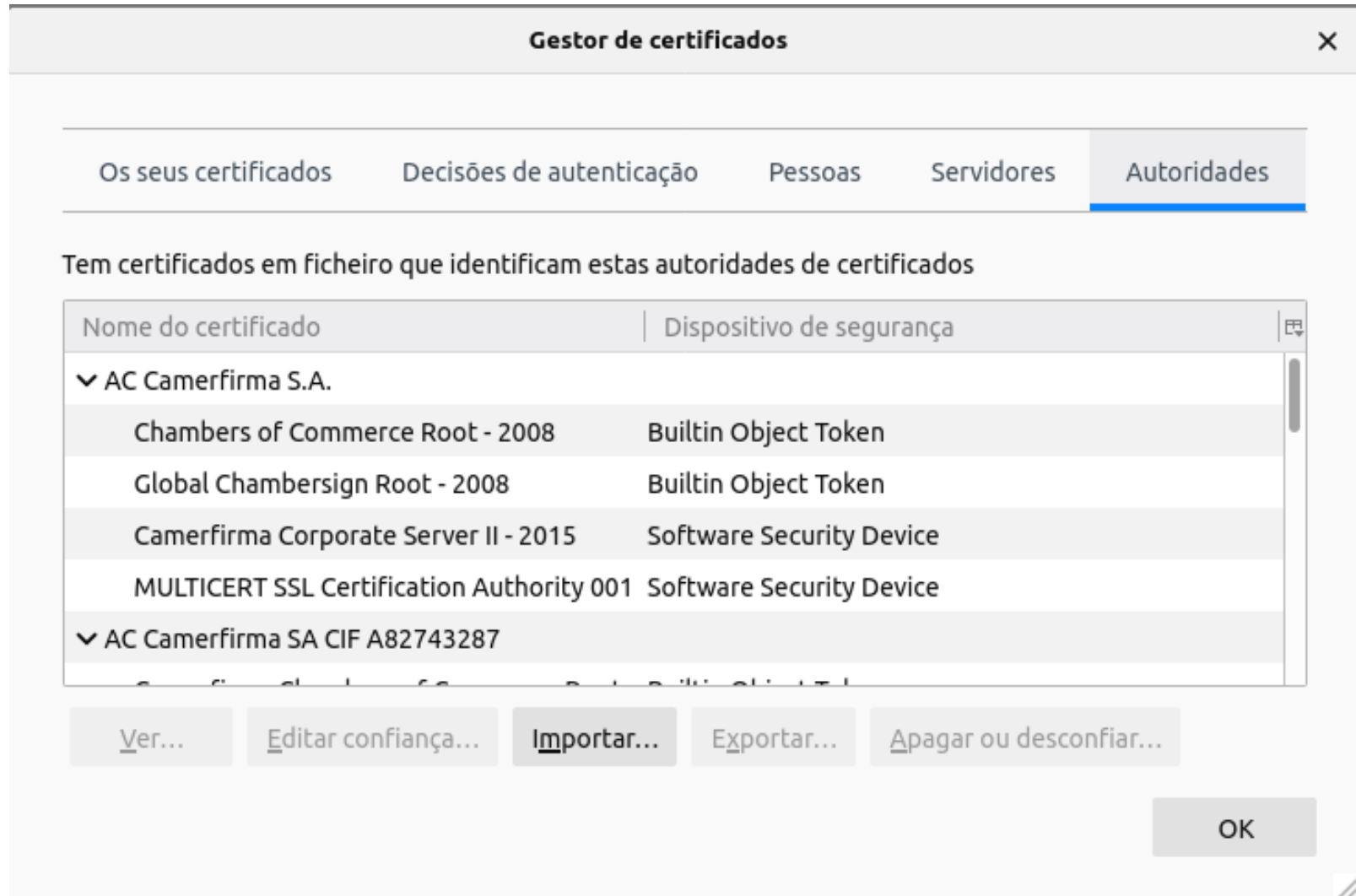


# Arquivo de Certificados (Windows)





# Arquivo de Certificados (Firefox)





# PKI - Infraestrutura de Chave Pública

---

- PKI - Public Key Infrastructure
- Infraestrutura composta por hardware, software, políticas e procedimentos necessários para gerir o ciclo de vida de certificados digitais
- Principais componentes:
  - **Entidades Certificadoras (CAs)**
  - Entidades de Registo (RAs)
  - Entidades de Validação (VA – Validation Authorities)
  - **Certificados Digitais**
  - Repositórios: Certificados, CRLs, ...
- Não envolve apenas aspetos técnicos
  - Envolve sobretudo aspetos legais
    - Certificate Policy (CP): Regras que regem as operações na PKI
    - Certificate Practice Statement (CPS): Detalha o processo de gestão de certificados



# Revogação de Certificados

---

- Um certificado revogado é um certificado invalidado antes do fim do seu período de validade
- Situações que implicam a revogação de um certificado:
  - Comprometimento, término da razão da sua existência, etc.
- Mecanismos de revogação de certificados:
  - CRL: Listas de Certificados Revogados (Certificate Revocation List)
  - OCSP: Online Certificate Status Protocol



# Proteção de dados em trânsito

---

- SSH – Secure Shell
- SSL / TLS - Secure Socket Layer / Transport Layer Security



# SSH – Secure Shell

---

- Protocolo de segurança para logins remotos
  - Substituir Telnet, rlogin e rsh que transmitem dados sem nenhuma proteção criptográfica
  - Inclui SFTP (FTP seguro) e SCP (cópia de ficheiros segura)
- Serviços fornecidos:
  - Confidencialidade dos dados
  - Integridade dos dados
  - Autenticação dos interlocutores
- Servidor SSH por omissão escuta no porto 22 do TCP



# SSH: Primeira ligação (autenticação do servidor)

---

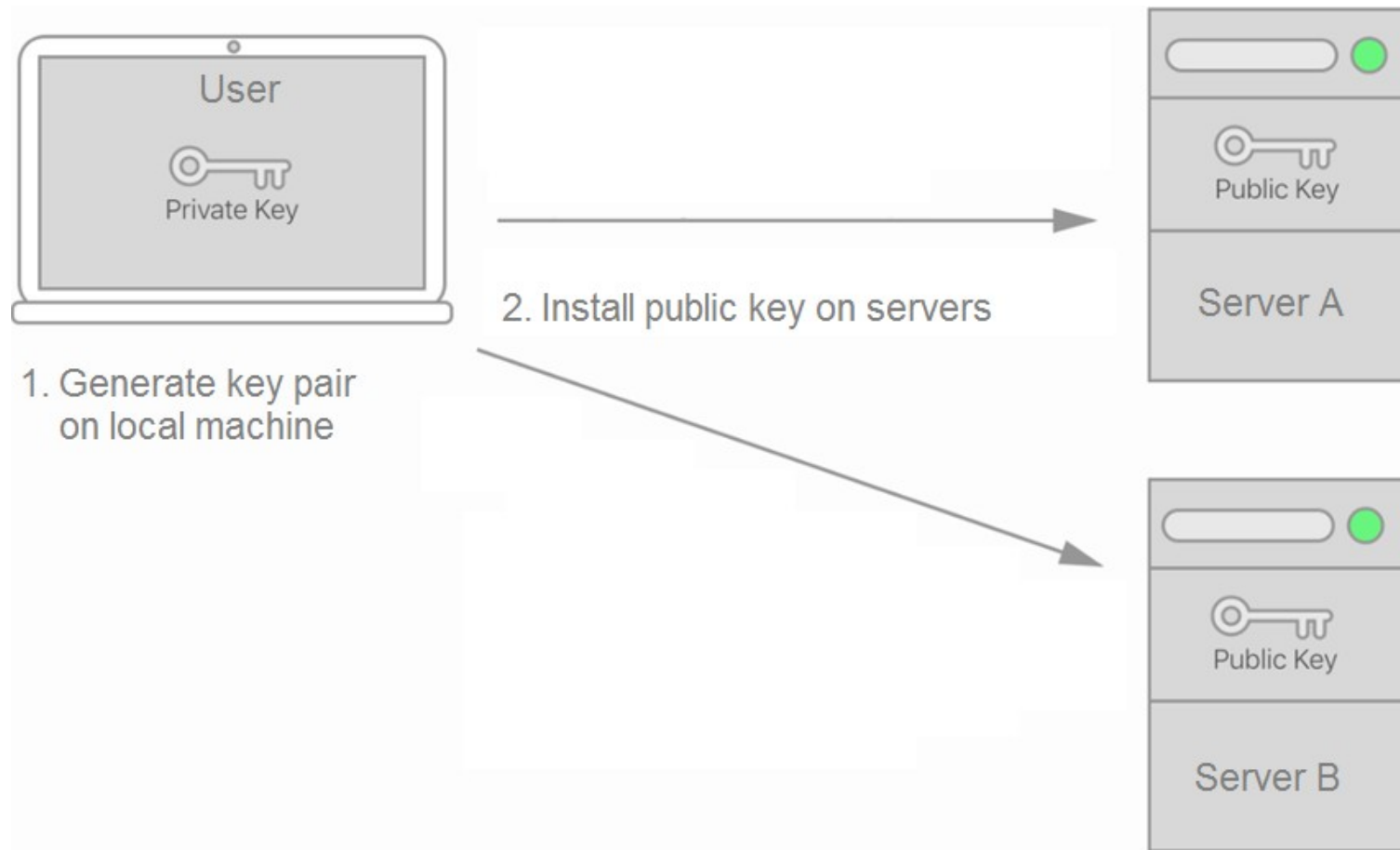
- `ssh username@remotehost`

```
The authenticity of host '111.111.11.111 (111.111.11.111)' can't be established.  
ECDSA key fingerprint is fd:fd:d4:f9:77:fe:73:84:e1:55:00:ad:d6:6d:22:fe.  
Are you sure you want to continue connecting (yes/no)? yes
```

- A não ser que haja uma alteração de chave no servidor, nas ligações subsequentes não é mostrado o fingerprint porque ele é guardado e validado pelo cliente.



# SSH: Par de chaves do utilizador

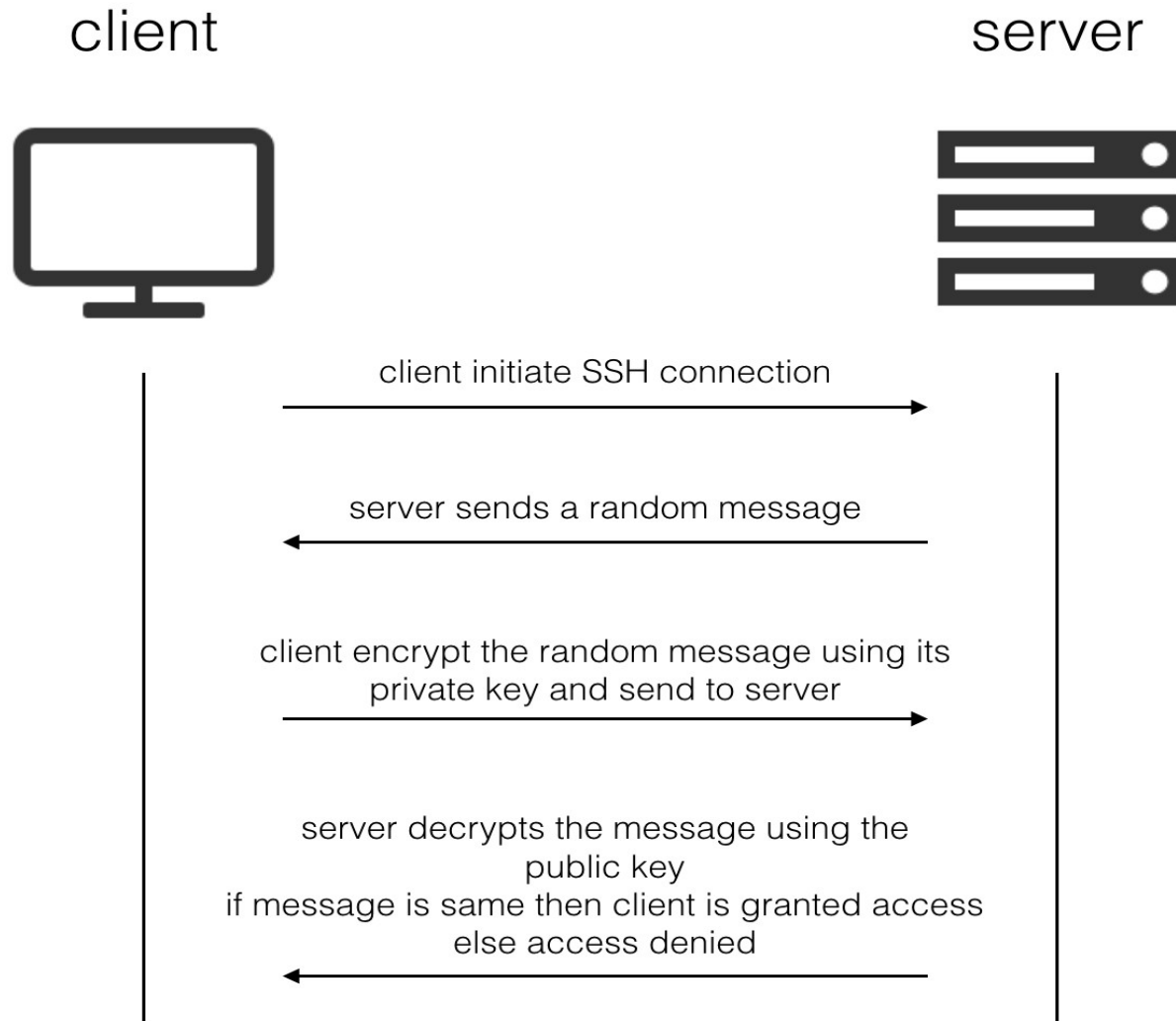






# SSH key based user authentication

## (Autenticação do cliente)





# SSL / TLS - Secure Socket Layer / Transport Layer Security

---

- Protocolos criptográficos que permitem comunicação segura sobre TCP/IP (inseguro)
  - SSL – Secure Sockets Layer
    - Desenvolvido pela Netscape em 1994 para proteger transações eletrónicas na Web
    - Não é recomendada a sua utilização
  - TLS – Transport Layer Security
    - Sucessor, criado a partir do SSL v3.0
    - Definido por uma entidade normalizadora: IETF
  - São técnica e filosoficamente quase iguais, mas não são compatíveis.
    - O que levou à manutenção dos dois em muitas aplicações
    - Ambos os termos são comumente utilizados de forma indiferenciada
-



# SSL/TLS: Modelo de Operação

---

- Modelo cliente-servidor
  - Tal como numa ligação TCP
- Clientes indicam:
  - Se é necessária autenticação do servidor
  - Quais os algoritmos que suporta (Cipher suites)
    - O servidor escolhe
- Gestão de sessões seguras sobre TCP/IP
  - Inicialmente concebido para tráfego HTTP
    - HTTPS: HyperText Transfer Protocol Secure (HTTP over SSL)
  - Atualmente usado também para outros tráfegos
    - IMAPS, SMTPS, ...



# SSL/TLS: Serviços de Segurança Disponibilizados

---

- Negociação de chaves
  - Suporta vários protocolos: O servidor escolhe de entre os propostos pelo cliente
  - Mais comum: RSA
    - Material para gerar chaves é enviado para o servidor, cifrado com chave pública deste
- Confidencialidade e integridade da comunicação
  - Cifra Simétrica e *Message Authentication Codes* (MAC)
- Autenticação de interlocutores
  - Através de certificados de chave pública



# SSL/TLS: Utilização pelas aplicações

- Duas interfaces
  - A convencional, com o porto de transporte habitual
  - Uma sobre SSL, com um porto de transporte novo
- Obriga a alterações nas aplicações para gerir a camada SSL

| Protocolos | Porto Normal | Porto TLS |
|------------|--------------|-----------|
| HTTP       | 80           | 443       |
| IMAP       | 143          | 993       |
| POP3       | 110          | 995       |
| SMTP       | 25           | 465       |
| LDAP       | 389          | 636       |



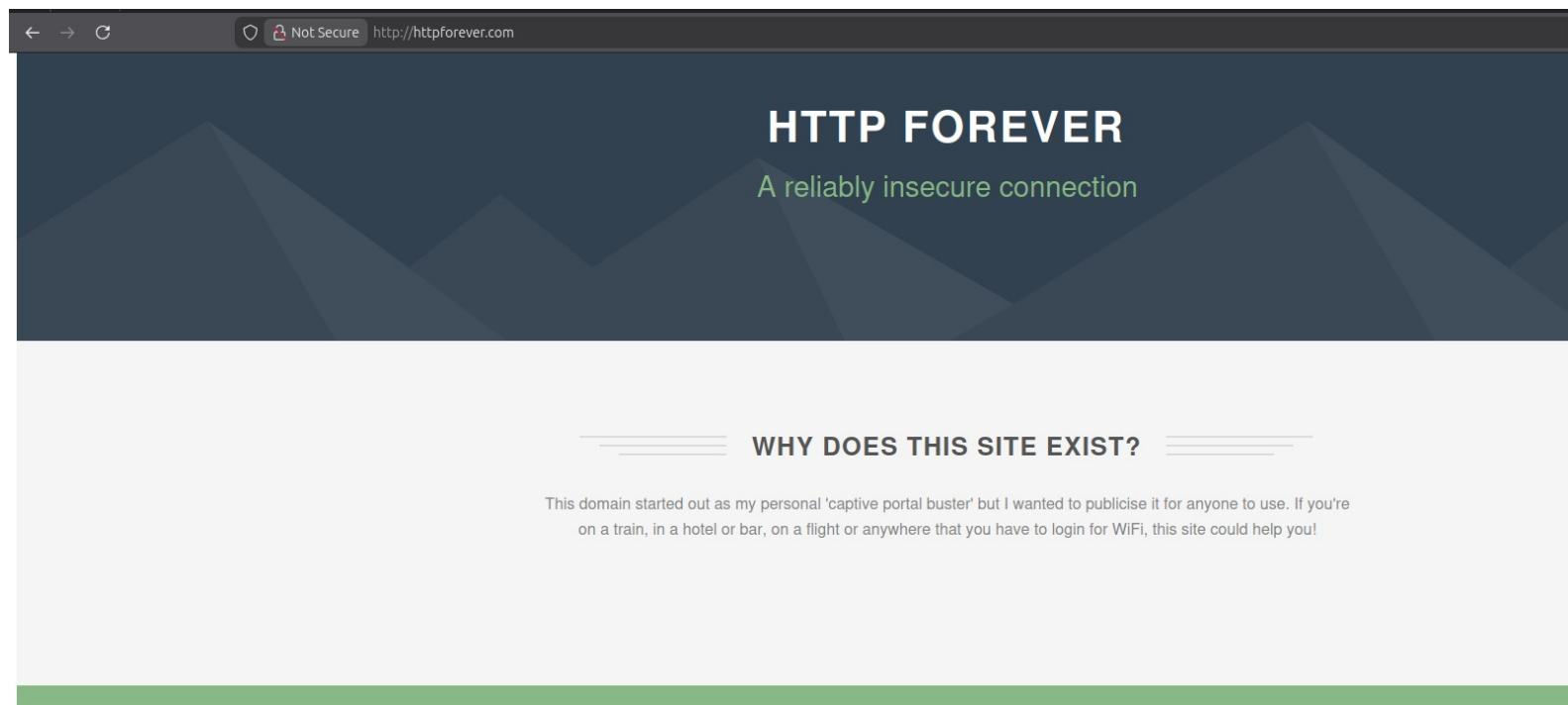
# Navegação na Web: HTTP



## **http://info.cern.ch - home of the first website**

From here you can:

- [Browse the first website](#)
- [Browse the first website using the line-mode browser simulator](#)
- [Learn about the birth of the web](#)
- [Learn about CERN, the physics laboratory where the web was born](#)





# Navegação segura na Web: HTTPS





# HTTPS: Exercício

---

- Inicie uma captura com o Wireshark sobre a Interface de rede do seu computador
- Aceda ao site da Câmara de Aveiro
  - [www.ua.pt](http://www.ua.pt)
- Pare a captura e analise o tráfego HTTPS capturado.
  - Consegue identificar o tráfego HTTPS?
  - Consegue observar os certificados trocados entre o servidor e o seu browser?
  - Que certificados foram trocados?





# Certificado apresentado por cm-aveiro.pt

## Certificate

|                          |                                                                           |                    |                                       |
|--------------------------|---------------------------------------------------------------------------|--------------------|---------------------------------------|
| *.cm-aveiro.pt           |                                                                           | GoGetSSL RSA DV CA | USERTrust RSA Certification Authority |
| <b>Subject Name</b>      |                                                                           |                    |                                       |
| Common Name              | *.cm-aveiro.pt                                                            |                    |                                       |
| <b>Issuer Name</b>       |                                                                           |                    |                                       |
| Country                  | LV                                                                        |                    |                                       |
| Locality                 | Riga                                                                      |                    |                                       |
| Organisation             | GoGetSSL                                                                  |                    |                                       |
| Common Name              | GoGetSSL RSA DV CA                                                        |                    |                                       |
| <b>Validity</b>          |                                                                           |                    |                                       |
| Not Before               | Mon, 16 May 2022 00:00:00 GMT                                             |                    |                                       |
| Not After                | Mon, 22 May 2023 23:59:59 GMT                                             |                    |                                       |
| <b>Subject Alt Names</b> |                                                                           |                    |                                       |
| DNS Name                 | *.cm-aveiro.pt                                                            |                    |                                       |
| DNS Name                 | cm-aveiro.pt                                                              |                    |                                       |
| <b>Public Key Info</b>   |                                                                           |                    |                                       |
| Algorithm                | RSA                                                                       |                    |                                       |
| Key Size                 | 4096                                                                      |                    |                                       |
| Exponent                 | 65537                                                                     |                    |                                       |
| Modulus                  | EA:EA:EC:8D:37:F0:5D:77:DE:C9:64:FB:DC:BE:68:E3:F0:D9:92:AB:7E:EC:4B:9... |                    |                                       |
| <b>Miscellaneous</b>     |                                                                           |                    |                                       |
| Serial Number            | 2C:AC:F3:C6:8A:9E:8F:06:AB:38:9F:AD:57:13:C1:8C                           |                    |                                       |
| Signature Algorithm      | SHA-256 with RSA Encryption                                               |                    |                                       |
| Version                  | 3                                                                         |                    |                                       |
| Download                 | <a href="#">PEM (cert)</a> <a href="#">PEM (chain)</a>                    |                    |                                       |



# Falha na autenticação do servidor

Warning: Potential Security Risk Ahead — Mozilla Firefox

Warning: Potential Security Certificate for portal.cm-viana-castelo.pt

Not Secure https://www.cm-viana-castelo.pt

**Warning: Potential Security Risk Ahead**

Firefox detected a potential security threat and did not continue to **www.cm-viana-castelo.pt**. If you visit this site, attackers could try to steal information like your passwords, emails, or credit card details.

[Learn more...](#)

[Go Back \(Recommended\)](#) [Advanced...](#)

www.cm-viana-castelo.pt uses an invalid security certificate.

The certificate is not trusted because it is self-signed.

Error code: [MOZILLA\\_PKIX\\_ERROR\\_SELF\\_SIGNED\\_CERT](#)

[View Certificate](#)

[Go Back \(Recommended\)](#) [Accept the Risk and Continue](#)



# Porquê a falha na autenticação?

Certificate for portal.cm-viana-castelo.pt — Mozilla Firefox

Warning: Potential Security Certificate for portal.cm-viana- +

Firefox about:certificate?cert=MIIDUzCCARYgAwIBAgICGjMwDQYJKoZIhvcNAQ... ☆

portal.cm-viana-castelo.pt

---

**Subject Name**

|                       |                                 |
|-----------------------|---------------------------------|
| Country               | --                              |
| State/Province/County | SomeState                       |
| Locality              | SomeCity                        |
| Organisation          | SomeOrganization                |
| Organisational Unit   | SomeOrganizationalUnit          |
| Common Name           | portal.cm-viana-castelo.pt      |
| Email Address         | root@portal.cm-viana-castelo.pt |

---

**Issuer Name**

|                       |                                 |
|-----------------------|---------------------------------|
| Country               | --                              |
| State/Province/County | SomeState                       |
| Locality              | SomeCity                        |
| Organisation          | SomeOrganization                |
| Organisational Unit   | SomeOrganizationalUnit          |
| Common Name           | portal.cm-viana-castelo.pt      |
| Email Address         | root@portal.cm-viana-castelo.pt |

---

**Validity**

|            |                               |
|------------|-------------------------------|
| Not Before | Thu, 15 Nov 2012 12:29:18 GMT |
| Not After  | Fri, 15 Nov 2013 12:29:18 GMT |

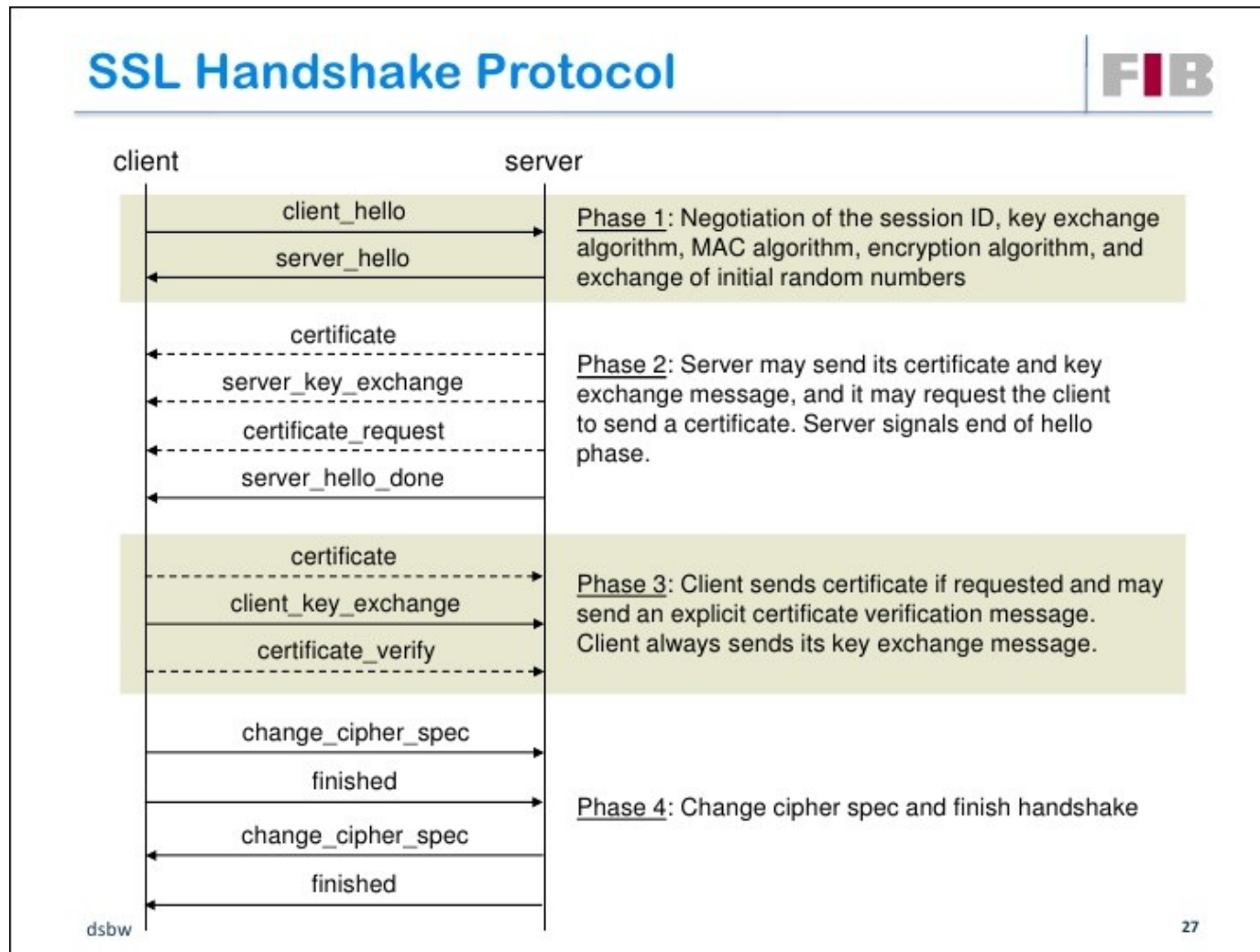


# SSL/TLS: *Handshake Protocol*

- Gere a criação e manutenção de sessões seguras
- Definição dos algoritmos criptográficos a usar
  - *Cipher Suite* *Cipher suite*: combinação de algoritmos de cifra, autenticação e MAC usada pelo SSL /TLS.
    - Cada combinação tem um nome, por exemplo: TLS\_ECDHE\_RSA\_WITH\_AES\_128\_GCM\_SHA256
      - TLS com chaves trocadas usando Ephemeral Elliptic Curve Diffie Helman (ECDHE), autenticação usando RSA, cifra usando AES com 128 bits em Galois Counter Mode e SHA256 como algoritmo hash para o calculo do MAC.
- Distribuição de chaves
  - Chave Mestra (Master Key)
    - Gerada com base numa pré-chave mestra e em valores aleatórios (nounces) gerados por ambos os interlocutores
    - Cliente gera uma pré-chave mestra (premaster key), que envia para o servidor (cifrada com chave pública do servidor)
  - Chaves de Sessão
    - Calculadas a partir da chave mestra (master key)
- Autenticação de interlocutores
  - Nenhuma
  - Autenticação do servidor (mais comum): certificado X.509
  - Autenticação mútua: certificados X.509



# SSL/TLS: *Handshake Protocol*





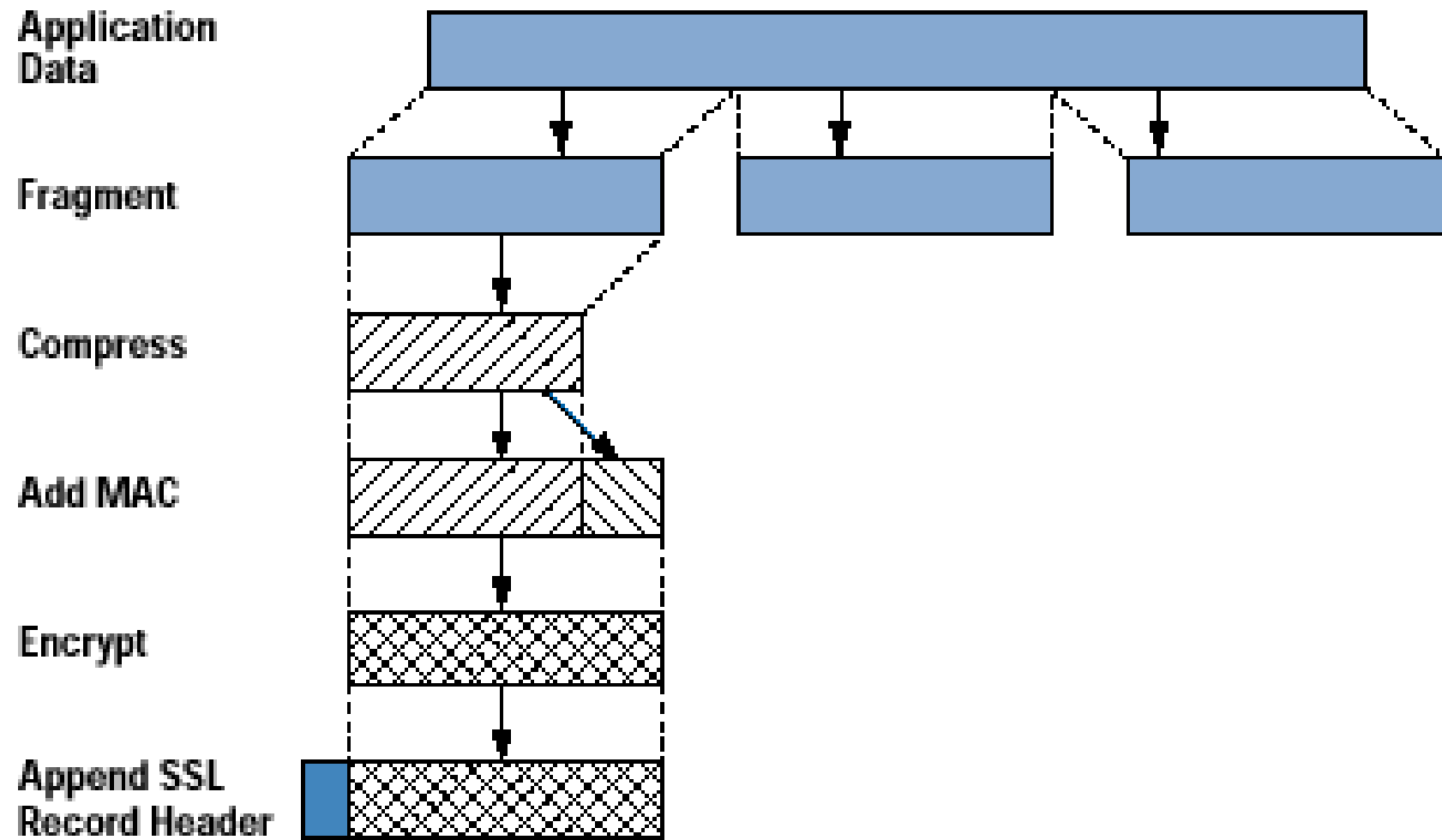
# SSL/TLS: *Transporte Seguro*

---

- Usa Chaves de Sessão derivadas da Chave Mestra (Master Key) obtida durante a autenticação
  - Quatro chaves: Uma para autenticidade e outra para integridade, diferentes em ambos os sentidos.
- Fornece:
  - Confidencialidade:
    - cifra da mensagens usando chaves de sessão derivadas da chave mestra (cifra simétrica)
  - Controlo de integridade:
    - usando chaves de sessão, derivadas da chave mestra, para calcular um Message Authentication Code (MAC), que é incluído na mensagem



# SSL/TLS: *Record Protocol*





# Verificação de Sites

---

- Online
  - <https://www.ssllabs.com/ssltest>
  - <https://webcheck.pt/pt/>
  - <https://www.hardenize.com/>
  - <https://www.immuniweb.com/>
- Linha de comando (Linux)
  - `testssl`





# Questões?

## Criptografia

Hélder Gomes ([helder.gomes@ua.pt](mailto:helder.gomes@ua.pt))

ESTGA-UA, 2022-23